



Lumi Reading

Security & Privacy Evidence Pack

Safer Technologies 4 Schools (ST4S) — supporting evidence

Lumi Education Pty Ltd

ABN 45 700 349 015

Compiled 24 July 2026 · **Confidential**

Contents

GOVERNANCE & POLICY

EV6	Information Security Policy	DRAFT
A6 / A7 / A13	Access Control Policy	DRAFT
GO1	Security Lead — Appointment	Pending signature
GO2	Privacy Officer — Appointment	Pending signature

SECURE OPERATIONS

EV13	Secure Development Lifecycle	DRAFT
T1	Security Monitoring Plan	DRAFT
T2 / T3	Patch & Vulnerability Management	DRAFT
T6 / T7	Incident Response Plan	DRAFT
EV7	Business Continuity Plan	DRAFT
EV8	Disaster Recovery Plan	DRAFT
D3	Backup Restore Drill — Record	Completed 2026-07-24 · signature pending

PEOPLE & ACCESS

HR1 / HR2 / HR3	HR Security Pack	DRAFT
HR2	Security Awareness Training — Record	Completed 2026-07-24 · signature pending
A7	Access Register (Privileged / Operator)	First review 2026-07-24 · signature pending
A10	Device Security Standard	DRAFT

PRIVACY & DATA

PR2	Privacy Policy (rewrite)	DRAFT — for adviser review
PR17	Sub-processor Register	DRAFT
PR10	Data Sharing Audit	DRAFT
INT7	Sub-processor Agreements (DPA) — Record	Template — to populate

ASSESSMENT EVIDENCE

EV11	Vulnerability Assessment Report	Final · 2026-07-24
S1 / S3 / S5	TLS & Cryptography Profile	Final · 2026-07-24

Each document is reproduced in full on the following pages. Status labels reflect state at compilation; drafts and unsigned records are marked as such.



Information Security Policy

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT

ST4S item: EV6 (information security policy), also evidences Q7 (management- endorsed security policy) and GO1 (named security officer) **Version:** 0.1
DRAFT · Date: 2026-07-24 **Status:** Draft for review — not yet signed

1. Purpose and scope

This policy is Lumi Reading's top-level statement of intent for protecting the personal information it holds — principally the reading and learning data of school children — and the systems that process it. It records management's commitment to information security, the legal obligations Lumi accepts, the governance roles that own security and privacy, and the mandatory controls every person working on Lumi must follow. It sits above, and points to, the operational documents that implement it (§9); those documents carry the file-cited technical detail and this policy does not repeat it.

Scope: everyone who builds, operates or supports Lumi (currently the Director, plus any contractor or adviser engaged), and every system in the estate — the Flutter app (`lib/**`), Cloud Functions (`functions/**`), the privileged core (`packages/server-ops/**`), the two Next.js portals (`school-admin-web/` , `admin/`), the marketing site (`marketing-site/`), the security rules (`firestore.rules` , `storage.rules`), and the data held in the (`lumi-ninc-au`) Google Cloud project (`australia-southeast1`). It also covers the third-party services Lumi relies on, through the vendor-management requirements in §8.

2. Management commitment

Lumi's management (the Director) is accountable for information security and commits to:

- treating the protection of children's personal information as a primary design and operating constraint, not an afterthought;
- resourcing and maintaining the controls in the operational documents this policy points to (§9), and the assessment and remediation programme that produced them (`docs/security/SECURITY_ASSESSMENT_ORCHESTRATION_PLAN.md` , `docs/ST4S_REMEDIATION_PLAN_2026-07-22.md`);
- reviewing this policy at least annually and after any material change or significant incident (§10);
- appointing and empowering the named security and privacy officers (§4).

This commitment is expressed as policy; it becomes governing only once signed (this is a draft, §11).

3. Legal and regulatory compliance

Lumi operates under Australian law and commits to comply with:

- the **Privacy Act 1988 (Cth)** and the **Australian Privacy Principles (APPs)**, including APP 8 (cross-border disclosure) obligations for the overseas services Lumi uses (Firebase Authentication is US-only; FCM, App Check, Analytics/Crashlytics and SendGrid are cross-border — each is inventoried and carries a required APP 8/contractual review in the vendor register, `docs/security/AU_RESOURCE_LOCATION_AUDIT_2026-07-17.md`);
- the **Notifiable Data Breaches (NDB) scheme** — breach assessment and notification are governed by the incident response plan and the underlying breach-response plan (§7);
- the **Student Data Privacy / Safer Technologies 4 Schools (ST4S)** assessment requirements against which this evidence pack is prepared.

Lumi's primary child-content plane (production Firestore, user-content Storage, all live Functions/Cloud Run) is hosted in Sydney (`australia-southeast1`); the documented cross-border exceptions and their review status are in the resource- location audit. Where a Lumi control depends on a legal determination — most importantly an NDB notification decision — the decision is reserved to qualified Australian privacy counsel and is **not** asserted as an in-house capability (§4, §11).

4. Governance roles (GO1 / GO2)

Two named roles own this policy in practice. While Lumi is small one person may hold both, but the responsibilities are distinct and every privileged action is recorded.

Role	ST4S	Owns	Holder
Security Lead	GO1	This policy; the technical controls, secure SDLC, access control, monitoring, incident detection/containment; the security assessment and findings register	Nic (Director)
Privacy Officer	GO2	Privacy compliance (APPs), the PIA/vendor register, cross-border (APP 8) assessments, NDB assessment coordination with external counsel, data-subject/school privacy enquiries	Nic (Director)

NOTE — appointment letters pending signature. The formal GO1/GO2 appointment letters that back these roles are **drafted but not yet signed**; [docs/security/ASSESSMENT_STATUS.md](#) records GO1/GO2 as *Not Ready*. The operational role assignments are already in effect (they are exercised in the access-control policy, the SDLC, the incident-response plan and the breach tabletop), but the signed letters are the outstanding governance artefact and must be executed for GO1/GO2 to be true (§11). The Privacy Officer's NDB / OAIC-liaison function additionally requires engaging external Australian privacy counsel (see the incident-response plan §2, §8).

5. Least privilege and mandatory MFA for privileged access

- **Deny-by-default, server-defined authorization.** Access to child, class and school data is governed by the Firestore/Storage security rules and server-written role fields — never by a client-asserted claim. A signed-in principal with no membership document is denied; there is no ambient access. The full model, the deployed create-time field-lock fixes (F-01...F-04) and the proven cross-tenant isolation are in the access-control policy ([docs/security/evidence/ACCESS_CONTROL_POLICY.md](#), [firebase.rules](#)).
- **Mandatory MFA for privileged accounts.** School administrators must complete authenticator (TOTP) MFA before the portal issues a session cookie; a password-only or SMS-only admin token is rejected until enrolment finishes, and any pre-rollout admin cookie is invalidated ([docs/ADMIN_TOTP_MFA_RUNBOOK.md](#)). At least two active administrator accounts are kept so recovery never depends on a locked-out person, and no administrator may disable their own final factor from an active session.
- **Least-privilege infrastructure identities.** Cloud Functions and each portal run under dedicated runtime service accounts (not the default App Engine account); the admin auto-deploy authenticates keylessly via GitHub OIDC / Workload Identity Federation with a predeploy identity audit that refuses the deploy on privilege drift ([.github/workflows/admin-deploy.yml](#), [infra/iam/audit-admin-build-identity.sh](#)).
- **No secrets in clients, builds or logs.** Secrets, Admin credentials and billable unrestricted keys must not enter a client, build artifact, log or Remote Config; this is enforced in CI by secret scanning over the full git history ([.github/workflows/secret-scan.yml](#); history is gitleaks-clean).

6. Acceptable use

Everyone with access to Lumi systems or data must:

- use access **only** for authorised Lumi operational and support purposes;
- protect their credentials, keep MFA enabled on every privileged account, and never share accounts or session cookies;
- keep the endpoints they use to access production reasonably secured and current (the device standard is a pending companion document — A10, §11);
- never place a secret, private key or personal information into source control, a build, a log, a transcript or a support ticket;
- handle child personal information on a strict need-to-know basis, and never export or copy it outside approved systems;
- report anything that looks like a security or privacy problem promptly (§7).

Misuse of access to Lumi data is treated as a serious matter and may end a person's access and engagement.

7. Duty to report incidents

Any suspected or confirmed security or privacy incident — a possible data exposure, a lost or compromised credential or device, a suspicious access pattern, a scanner or researcher report — **must be reported without delay** to the Security Lead. Reporting is a duty, not a discretion, and good-faith reports are never penalised. The response is then governed by the incident response plan ([docs/security/evidence/EV9_INCIDENT_RESPONSE_PLAN.md](#)), which defines detection channels, triage/severity, containment, eradication, recovery, the NDB notification assessment (led with external counsel), the incident register, and the blameless post-incident review. External reports are received at the monitored, MFA-protected support intake mailbox recorded in that plan (a role mailbox, not a personal address).

8. Third-party and supply-chain security

- **Vendor register.** Every third-party service that processes Lumi data is inventoried with its processing location and cross-border/APP 8 status. The live inventory of platform services and their exception status is [docs/security/AU_RESOURCE_LOCATION_AUDIT_2026-07-17.md](#); the standing vendor / PIA register is maintained on the recurring schedule in [docs/privacy/RELEASE_PRIVACY_SECURITY_REVIEW.md](#) (quarterly vendor/PIA review).
- **Assess before adopting.** A new SDK, dependency or processor that touches personal information is not adopted until its data flow, processing location, sub-processors and a written data-processing/APP 8 position have been reviewed and recorded — this is a required item on the release privacy/security review gate. Data-sharing and written data-processing agreements are tracked as ST4S PR10 / PR17 / INT7 items (a separate privacy workstream requiring privacy counsel — §11).
- **Supply-chain integrity in the pipeline.** Dependencies are centrally updated and scanned (Dependabot + osv-scanner SCA + semgrep SAST + production [npm/pnpm audit](#)), and remediated under the patch-management process ([docs/security/evidence/EV12_PATCH_MANAGEMENT.md](#), [docs/security/evidence/EV13_SECURE_SDLC.md](#)).

9. Policy framework — documents this policy governs

This policy is the apex; the operational controls live in, and are evidenced by:

Area	Document
Access control, least privilege, review (A6/A7/A13/A5)	docs/security/evidence/ACCESS_CONTROL_POLICY.md

Area	Document
Secure development lifecycle + CI security gates (EV13/Q5)	docs/security/evidence/EV13_SECURE_SDLC.md
Patch management (EV12/T2/T3)	docs/security/evidence/EV12_PATCH_MANAGEMENT.md
Monitoring + security testing (T1/AP1)	docs/security/MONITORING_PLAN.md
Incident response + register + breach notification (EV9/T6/T7)	docs/security/evidence/EV9_INCIDENT_RESPONSE_PLAN.md , docs/privacy/DATA_BREACH_RESPONSE_AND_TABLETOP.md
Business continuity (EV7)	docs/security/evidence/EV7_BUSINESS_CONTINUITY_PLAN.md
Disaster recovery (EV8/D3)	docs/security/evidence/EV8_DISASTER_RECOVERY_PLAN.md
Privileged MFA runbook (A5)	docs/ADMIN_TOTP_MFA_RUNBOOK.md
Release privacy/security review gate	docs/privacy/RELEASE_PRIVACY_SECURITY_REVIEW.md

10. Review and maintenance

- This policy is reviewed **at least annually**, and additionally after any material change to the estate, any change of holder for a governance role, or any significant security or privacy incident.
- The recurring operational reviews that keep the underlying controls honest — weekly automated security review, monthly IAM/keys review, quarterly vendor/PIA review, six-monthly breach tabletop — are defined in [docs/privacy/RELEASE_PRIVACY_SECURITY_REVIEW.md](#) and evidenced by the CI workflows in [.github/workflows/](#).
- Each review is recorded with a date, the reviewer, and any change; the version and date at the head of this document are bumped on every substantive change.

11. Known gaps (for the reviewer)

- **GO1/GO2 appointment letters pending signature.** The named Security Lead and Privacy Officer roles are operationally assigned but the formal appointment letters are **unsigned** ([ASSESSMENT_STATUS.md](#) records GO1/GO2 as *Not Ready*). This is the top governance gap: until the letters are signed, GO1/GO2 cannot be claimed as met.
- **External privacy counsel for NDB / APP 8.** The Privacy Officer's breach- notification and cross-border-assessment functions require engaging qualified Australian privacy counsel; this policy must not be read as asserting an in-house NDB decision capability.
- **Device standard (A10) pending.** §6 references a companion endpoint/device standard that is drafted-but-pending; confirm it is completed and adopted.
- **Privacy pack pending (PR2/PR10/PR17/INT7).** The public privacy policy, sub-processor disclosure, data-sharing audit and written data agreements are a separate privacy-counsel workstream and are not yet complete; §3/§8 reference the obligations, not completed artefacts.
- **Sign-off.** This policy requires the Director's signature (and the signed GO1/GO2 letters) before it is the governing document.

Lumi Reading · Security & Privacy Evidence

A6 / A7 / A13

Access Control Policy

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT

ST4S items: A6 (access control), A7 (access review), A13 (least privilege / deny-by-default) **Related:** A5 (privileged-access MFA) **Version:** 0.1 DRAFT · **Date:** 2026-07-24 **Status:** Draft for review — not yet signed

1. Purpose and scope

This policy defines who may access what in Lumi Reading, how each role is authorized, and how access is kept least-privilege and reviewed. It covers the application's own access model — the Firestore/Storage security rules and server-owned role fields that govern parent, teacher, school-admin and super-admin access to child, class and school data — and the privileged operational access to the `lumi-ninc-au` project. Every control below is implemented and cited by file path.

Design principle: **authorization is server-defined, never client-asserted**. Every authorization decision derives from a server-written membership document or a server-owned field, not from a client-supplied claim or token attribute that the client could set itself. This was validated in the 2026-07 self-managed assessment (`docs/security/VULNERABILITY_ASSESSMENT_REPORT_2026-07-24.md`, \$7 Positive assurance).

2. Role model

Role	Identity record	Scope of access
parent	<code>/schools/{schoolId}/parents/{uid}</code> (with <code>linkedChildren</code>)	Read/limited-write for their own linked children only, within one school
teacher	<code>/schools/{schoolId}/users/{uid}</code> with <code>role: 'teacher'</code>	Their own classes (via the class doc's <code>teacherId</code> / <code>teacherIds</code>) and those classes' students, within one school
schoolAdmin	<code>/schools/{schoolId}/users/{uid}</code> with <code>role: 'schoolAdmin'</code>	Their whole school — staff/parent directories, classes, students, allocations, settings
superAdmin	<code>/superAdmins/{uid}</code> (deny-all to clients)	Lumi internal operations across tenants, via the super-admin portal only

A signed-in principal with **no** membership document for a given school is denied — there is no ambient/default access.

3. How each role is authorized

3.1 Membership documents are server-written

Role comes from the membership document, and the security rules make those documents un-self-grantable (`firestore.rules`):

- Teacher** (`/schools/{schoolId}/users/{userId}`): client teacher self-create was **removed**. A legitimate teacher document is written **server-side** (Admin SDK, bypassing rules) by the signup callables after a valid school-code check. The only client `create` paths that remain are an existing `schoolAdmin` provisioning staff, or the first-admin bootstrap of a school the caller just created (`firestore.rules:418-429`). This closes the historical teacher self-provisioning class — self-create previously let any account holder become a teacher of any school and read every child's PII.
- Parent** (`/schools/{schoolId}/parents/{parentId}`): `allow create: if false` (`firestore.rules:480`). Parent profiles and their `linkedChildren` are created only server-side by the signup/linking callables after verifying a live child code — a bare signed-in account cannot join an arbitrary school id.
- Self-updates are field-locked:** a user/parent may update only a small allowlist of own-profile fields (`preferences`, `fcmToken`, `lastLoginAt`, `relationshipLabel`, `characterId`, terms-acceptance). `role` and `schoolId` are pinned to their prior value on every self-update (`firestore.rules:436-460`, `487-508`). Entitlement/rate-limit/MFA-state fields are writable only from a trusted server source.

3.2 Role is resolved by reading the server doc, in-rules

The rules resolve a caller's role by reading their membership document (`getUserData` / `userRole`, `firestore.rules:16-42`) — `isSchoolAdmin`, `isTeacher`, `isParentMember` all derive from the server-written doc, never from a token claim. Teacher↔class ownership is resolved from the class document's `teacherId` / `teacherIds` (`teacherTeachesClass`, `firestore.rules:94-103`), the single source of truth for that relationship.

3.3 Super-admin is a Firestore doc, checked identically in three places

Super-admin status is the existence of a `/superAdmins/{uid}` document (with a `SUPER_ADMIN_UIDS` env value as a bootstrap-only fallback). The check is implemented three times, kept deliberately in sync:

- Portal session/auth — `admin/src/lib/auth-firestore.ts#isSuperAdminViaFirestore` (used by `admin/src/lib/auth.ts`, `admin-auth-guard.ts`).

- Cloud Functions — `functions/src/super_admin.ts#isSuperAdmin`.
- Privileged core — `packages/server-ops/src/authority.ts#assertSuperAdmin`.

The `/superAdmins/{uid}` collection is `allow read, write: if false` to all clients (`firestore.rules:1536-1537`), so it can only be managed server-side.

4. Deny-by-default posture (A13)

The rules are deny-by-default and defence-checked:

- **Implicit deny + explicit deny.** No path is readable/writable unless a rule grants it, and ~20+ server-only collections/subcollections carry an explicit `allow read, write: if false` (e.g. `/superAdmins`), and the server-owned docs at (`firestore.rules:1140, 1264, 1284, 1368-1587`). There is no recursive wildcard grant.
- **Tenant isolation is structural.** Every per-school path binds `schoolId`, and there is **no** client `collectionGroup` rule, so an unscoped cross-tenant collection-group sweep cannot be authorised. This was proven dynamically: a school-A teacher can neither read school-B data directly nor sweep it via a collection-group query (`functions/test/security_poc.rules.test.js`, the "S4 tenant isolation" test).
- **Server-owned fields are locked on create and update.** A shared server-owned-field denylist guards both paths, so an entitlement or ownership field cannot be forged at creation time (see §5).
- **Fail-closed entitlement.** `studentAccessLive` (`firestore.rules:134-138`) uses safe `.get(key, default)` accessors so a missing `access` map evaluates to **denied**, and an absolute `expiresAt` backstop lapses access on schedule even if no Cloud Function runs.

5. Deployed access-control hardening (F-01 ... F-04)

The 2026-07 assessment identified and **fixed + deployed** four access-control findings; each rules fix carries an emulator regression test wired into CI:

- **F-01 — student-create field-lock.** The student `create` rule omitted the server-owned-field denylist the `update` rule enforced, so a schoolAdmin/teacher could mint a student that is entitlement-live from creation, bypassing the single licensing-enforcement point. Fixed with one shared field list guarding create and update; regression test (`security_poc.rules.test.js`) (F-01 a/b/c). Deployed (`firestore:rules`) (PR #520 / `0d31809`).
- **F-02 — school-create commercial-field guard.** School `create` omitted the guard the `update` path enforced, letting a creator self-seed `subscription` / `access` / `accessMode` / `isDemo`. Fixed + regression test. Deployed.
- **F-03 — class ownership lock.** Class `update` let a teacher-of-class reassign `teacherId` / `teacherIds` (hand the class to an attacker uid or remove themselves). Fixed with a `classOwnershipUnchanged()` guard on the teacher branch (schoolAdmins retain reassignment); regression test. Deployed.
- **F-04 — in-module super-admin authz on destructive server-ops.** The five destructive super-admin operations (offboard a school, delete parent accounts, grant dev-access, disable staff auth, manage school-user auth) had no internal authorization — the only gate was the calling portal route's session check (single-layer). A fail-closed `assertSuperAdmin(db, actor.uid)` now runs **inside** the ops (`packages/server-ops/src/authority.ts`), so a route that ever forgets to gate fails **closed** instead of executing. Unit test (`authority.parity.test.ts`). Deployed via `admin-deploy` (PR #561 / `6d5b795`).

Two lower-severity access-adjacent findings are **accepted-by-design** with written rationale: F-06 (Storage cover first-claim — Storage rules cannot read Firestore for role; covers are non-personal; uploader-uid and no-overwrite protections stand) and F-08 (portal CSRF resting on `SameSite=Lax`). See the findings register for dispositions.

6. Privileged access and MFA (A5)

- **Mandatory authenticator (TOTP) MFA for school administrators.** A school administrator must complete TOTP MFA before the portal issues its server session cookie; teachers retain password/SMS. **Source:** `docs/ADMIN_TOTP_MFA_RUNBOOK.md`.
 - A password-only or phone-MFA-only admin ID token is **rejected** by `/api/auth/session` until TOTP enrolment finishes; any admin cookie minted before the rollout is rejected and must be replaced by a new MFA-verified login. A valid TOTP login mints an HttpOnly, Secure (production), SameSite=Lax cookie.
 - Lost-device recovery is performed only by a separately authenticated support operator via the Admin SDK, recorded in the security audit log; an administrator can never disable their own final factor from an active session, and two active admin accounts are kept so recovery never depends on the locked-out person.
 - Emergency rollback is the short-lived `ADMIN_TOTP_ENFORCED=false` flag only.
- **Super-admin portal** authenticates against `/superAdmins/{uid}` (§3.3) with its own runtime service account and session secret; the seeded read-only sales-demo admin is the only MFA-exempt admin shape and is confined to a synthetic tenant, read-only (`firestore.rules:184-191`, `demoAdminReadOnly`).

7. Least privilege — infrastructure identities (A13)

- **Dedicated runtime identities.** Cloud Functions run as `lumi-functions-runtime@lumi-ninc-au.iam.gserviceaccount.com` (not the default App Engine/appspot account); the two portals each have their own runtime service account. Scheduler/Eventarc-backed services grant `run.invoker` to the runtime identity per-service, and obsolete default-account bindings are removed (`docs/security/OPERATIONS_HEALTH_AUDIT_2026-07-17.md`).
- **Keyless CI deploy.** The admin auto-deploy authenticates via GitHub OIDC / Workload Identity Federation — no JSON private key is stored; the provider condition accepts only this repo's `main` branch, and the SA binding is scoped to that principal. A predeploy identity audit (`infra/iam/audit-admin-build-identity.sh`) **refuses the deploy** if the build or runtime identity drifts to a default account or gains project-data/secret/key access (`.github/workflows/admin-deploy.yml`).

- **No credentials in clients or builds.** The release gate forbids any secret, Admin credential or billable unrestricted key from entering a client, build artifact, log or Remote Config; secret scanning enforces it in CI (`.github/workflows/secret-scan.yml` ; history is gitleaks-clean).

8. Access review cadence (A7)

Access type	Review trigger	Frequency	Evidence
Membership (parent/teacher/schoolAdmin)	On role change (provision / offboard) and on the school's annual rollover	Continuous + annual	Server-op offboarding; rollover import (soft-archive)
Super-admin (<code>/superAdmins</code>)	On any addition/removal; reviewed at least annually	Annual + on change	<code>/superAdmins</code> collection membership
IAM roles / service accounts / deploy WIF	Monthly and after any deployment change	Monthly	IAM export + capability canaries (release-gate schedule)
Privileged portal sessions / MFA factors	On staff change; lost-device recovery on demand	On change	<code>docs/ADMIN_TOTP_MFA_RUNBOOK.md</code>

Membership changes are **event-driven** (an admin provisions/offboards staff; a parent link is created/removed by callable; rollover soft-archives departed students), which keeps day-to-day access current between the calendar reviews. The **monthly IAM review** and the periodic privileged-access review are defined in the release-gate recurring-schedule table (`docs/privacy/RELEASE_PRIVACY_SECURITY_REVIEW.md`).

9. Known gaps (for the reviewer)

- **Access register (A7).** This policy names *where* each role lives and *when* it is reviewed, but a standing **access register** (the enumerated list of current super-admins and privileged human accounts with review dates) is a document Nic must own and keep — confirm it exists and is current.
- **Annual review sign-off.** The cadence table asserts annual super-admin and monthly IAM reviews; confirm these are actually being performed and recorded (not only documented), and that a named owner signs each off.
- **App Check (F-05).** Client attestation (App Check) enforcement on callables is currently **off** — a launch-gated control (valid store-signed attestation needs the published app). It is tracked separately; note it here so the policy is not read as claiming App Check is enforced today.
- **Sign-off.** This policy requires Nic's sign-off before it is treated as the governing document.



Lumi Reading · Security & Privacy Evidence

GO1

Security Lead — Appointment

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

PENDING SIGNATURE

Version 0.1 — DRAFT for signature · 2026-07-24 *This is a one-page appointment letter. Fill the [bracketed] fields, sign, date, and save a PDF to the evidence pack (folder **GO**). Remove this instruction line before signing.*

LUMI EDUCATION PTY LTD ABN 45 700 349 015 (*confirm*) · trading as Lumi Reading

Appointment of Security Lead (Cyber Security Officer)

Appointee: Nicholas Plevritis **Role:** Security Lead — the named person responsible for cyber security at Lumi Education Pty Ltd. **Effective date:** [DD Month 2026]

Lumi Education Pty Ltd appoints the person named above as its **Security Lead**. In this role you are responsible and accountable for the following, and are given the authority and resources reasonably needed to carry them out:

1. **Coordinating and reporting on cyber security** across the organisation, including reporting the security posture to management (for a sole-founder company, this is a documented monthly self-review).
2. **Security risk management**, including supply-chain / third-party risk (maintaining the vendor & data-flow register and requiring a DPA check before any new vendor or SDK is adopted).
3. **Driving security improvement activities** (e.g. the remediation plan, vulnerability assessments, and closing findings).
4. **Security awareness and training** — ensuring the annual security awareness training is delivered and recorded.
5. **Leading incident response** in line with the Incident Response Plan (EV9), including containment, recovery, and breach notification decisions.
6. **Reviewing this appointment and the Information Security Policy at least annually.**

External escalation / specialist support: where an issue exceeds in-house capability, escalate to **[external security adviser — name & contact]**.

Signed by the appointee:

Name: Nicholas Plevritis Signature: _____ Date: _____

Signed for Lumi Education Pty Ltd:

Name: Nicholas Plevritis Title: Director Signature: _____ Date: _____

(For a sole founder, both signatures are yours — that is expected and acceptable for ST4S.)



Lumi Reading · Security & Privacy Evidence

GO2

Privacy Officer — Appointment

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

PENDING SIGNATURE

Version 0.1 — DRAFT for signature · 2026-07-24 *One-page appointment letter. Fill the [bracketed] fields, sign, date, and save a PDF to the evidence pack (folder **GO**). Remove this instruction line before signing.*

LUMI EDUCATION PTY LTD ABN 45 700 349 015 (*confirm*) · trading as Lumi Reading

Appointment of Privacy Officer

Appointee: Nicholas Plevritis **Role:** Privacy Officer — the named person responsible for privacy at Lumi Education Pty Ltd. **Effective date:** [DD Month 2026]

Lumi Education Pty Ltd appoints the person named above as its **Privacy Officer**, with responsibility and authority for the following:

1. **Providing internal privacy advice** and promoting compliance with the Australian Privacy Act and the Australian Privacy Principles (APPs).
2. **Being the liaison point with the OAIC** (Office of the Australian Information Commissioner) and any regulators.
3. **Handling privacy enquiries, complaints, and access & correction requests** from parents, schools, and other individuals.
4. **Maintaining the record of personal-information holdings** — kept current via the Privacy Impact Assessment and the Vendor & Data-Flow Register.
5. **Assisting with Privacy Impact Assessments** for new features or data flows.
6. **Measuring performance against the privacy management plan** and reviewing this appointment at least annually.
7. **Leading privacy-breach assessment and notification** (Notifiable Data Breaches scheme) in coordination with the Security Lead and the Incident Response Plan.

External escalation / specialist support: for complex matters (e.g. APP 8 cross-border, NDB thresholds), escalate to **[external privacy adviser / lawyer — name & contact]**.

Signed by the appointee:

Name: Nicholas Plevritis Signature: _____ Date: _____

Signed for Lumi Education Pty Ltd:

Name: Nicholas Plevritis Title: Director Signature: _____ Date: _____



Secure Development Lifecycle

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT

ST4S item: EV13 (also evidences Q5 — security testing to a framework) **Version:** 0.1 DRAFT · **Date:** 2026-07-24 **Status:** Draft for review — not yet signed

1. Purpose and scope

This document describes Lumi Reading's actual secure development lifecycle: how a change moves from design, through peer review and automated CI gates, to a gated deployment, and how it is rolled back. Every control described here is implemented in the repository and cited by file path. Where a control is partial or pending, it is called out explicitly (see §11).

Scope: the Lumi monorepo (`lumi-ninc-au` , `australia-southeast1`) — the Flutter app (`lib/**`), Cloud Functions (`functions/src/**`), the privileged core (`packages/server-ops/**`), the two Next.js portals (`school-admin-web/` , `admin/`), the marketing site (`marketing-site/`), and the security rules (`firestore.rules` , `storage.rules`).

2. Lifecycle overview

```
design/review → branch + PR → automated CI gates → merge → gated deploy → monitor / rollback
(§3, §4)          (§3)          (§5, §6)          (§3)          (§7, §8)          (§9, §10)
```

Two principles govern the flow:

- **Authorization is server-defined, tested as code.** The security boundary is the Firestore/Storage rules plus server-owned role fields, so rules changes are treated as code and gated by an emulator test suite (§6).
- **Deploys are deliberate.** Only the admin portal auto-deploys from `main` (`.github/workflows/admin-deploy.yml`). Cloud Functions, security rules, Firestore indexes, the school portal and the Flutter app are all deployed by an explicit, human-run `firebase deploy` / release step (§7).

3. Change management — branch → PR → squash-merge

Every non-trivial change is made on a prefixed branch (`feat/` , `fix/` , `refactor/` , `docs/` , `sec/`), pushed, opened as a pull request, and squash-merged into `main` with the branch auto-deleted. The squash commit message names the change (and, for security work, the ST4S item it addresses), which keeps `git log` a usable audit trail — every fix in the current security programme is a single named squash commit (e.g. rules fixes `0d31809` / PR #520, MFA-crypto `96b4cce` / PR #557, server-ops authz `6d5b795` / PR #561).

Pull requests are the review surface: a human reviewer plus the automated gates in §5–§6 must be satisfied before merge.

4. Design / release security-and-privacy review gate

A structured review gate applies to any change touching sensitive surfaces — auth/sessions/roles/tenancy, security rules or schemas, child/parent/staff personal information, audio/AI, analytics/logging, vendors/secrets/processing location, retention/deletion, or abuse-sensitive endpoints.

Source: `docs/privacy/RELEASE_PRIVACY_SECURITY_REVIEW.md`.

The gate has three checklists:

1. **Pull-request checklist** — state the personal data and principals affected; describe the expected school → class → child binding; require positive *and* negative (cross-tenant denial) tests; validate every accepted field/type/range and lock system fields; check subcollections and Storage separately; confirm queries are scope-bound; confirm no secret or Admin credential reaches a client/build/log; update the PIA/vendor register where relevant.
2. **Release evidence checklist** — Functions/unit tests pass; Firestore and Storage rules emulator suites pass; Flutter analysis and tests pass; portal typecheck/build pass where changed; production dependency audits carry no accepted critical/high (or a time-limited, owned exception); gitleaks clean; reviewed rules/config match the live deployment hashes.
3. **Recurring schedule** — weekly automated review, monthly IAM/keys review, quarterly vendor/PIA review, six-monthly breach tabletop (see the doc's schedule table, and §5/§9 below).

An unchecked mandatory item blocks release unless the named approver records a time-limited exception.

5. Continuous-integration gates

All workflows live in `.github/workflows/`. Triggers and enforcement:

5.1 demo-readiness.yml — the full regression gate (blocking)

- **Trigger:** every pull request, and push to `main`, that touches app, functions, portals, rules, or lockfiles (path-filtered); also manual dispatch.
- **Environment (pinned):** Node 22, Java 21 (Temurin), Flutter **3.44.6** (deliberately pinned — a floating `stable` channel previously turned `main` red on upstream Flutter releases; the pin is documented inline in the workflow).
- **Enforces** (`pnpm test:demo-readiness` → `scripts/demo-readiness-local.sh`): server-ops demo-plan/preflight/control tests, a demo-reseed emulator integration test, the Functions read-only-guard test, the **Firestore rules emulator suite** and the **Storage rules emulator suite** (§6), the full Flutter test suite plus `flutter analyze` on `lib/`, the school-portal security test + `tsc --noEmit`, and the admin-portal `tsc --noEmit`.
- A red run blocks the PR.

5.2 admin-ci.yml — admin/portal build gate (blocking)

- **Trigger:** PRs and push to `main` touching `admin/**`, `packages/**`, the audio-authority/cover-OCR sources, or lockfiles.
- **Enforces:** audio-authority parity, **feature-flag parity** (portal and Cloud Functions must resolve the same flag docs to the same state — a drift would silently mis-display a kill switch), TypeScript typecheck, lint, and a full Next build.

5.3 security-review.yml — weekly automated security review

- **Trigger:** scheduled `17 2 * * 1` (Mondays 02:17 UTC) + manual dispatch.
- **Enforces:** Functions unit tests (`npm run test:functions`), the **Firestore rules emulator suite** (`npm run test:rules`), a Functions production dependency audit (`npm audit --omit=dev --audit-level=high`), and a portal production dependency audit (`pnpm audit --prod --audit-level high`).

5.4 secret-scan.yml — secret scanning (gitleaks)

- **Trigger:** push to `main`, **every** pull request, and manual dispatch.
- **Enforces:** `gitleaks` v8.30.1 over the **complete git history** (`fetch-depth: 0`, `--redact=100`), honouring `.gitleaksignore`. The current history is gitleaks-clean.

5.5 sca-osv.yml — software composition analysis (osv-scanner)

- **Trigger:** monthly `17 3 1 * *` (1st of month, 03:17 UTC) + manual dispatch.
- **Enforces:** `osv-scanner` (Google action v2) recursively over every lockfile (npm + pub), uploading SARIF to the GitHub Security tab. **Report-only** (`continue-on-error`) while the findings register is triaged. The per-PR trigger is intentionally disabled pending action-ref verification (documented inline; re-enable once a green baseline confirms the config).

5.6 sast-semgrep.yml — static application security testing (semgrep)

- **Trigger:** monthly `23 3 1 * *` (1st of month, 03:23 UTC) + manual dispatch.
- **Enforces:** `semgrep scan` with community rulesets (`p/default`, `p/typescript`, `p/javascript`, `p/secrets`), uploading SARIF to the Security tab. **Report-only** while the baseline is triaged. Per-PR trigger disabled for the initial landing (documented inline). The current SAST baseline is one low finding (SAST-01, now fixed) with no secrets flagged.

5.7 dependabot.yml — dependency update automation

- **Source:** `.github/dependabot.yml`. **Weekly** updates for: npm in `/functions`, `/school-admin-web`, `/admin`, `/marketing-site` and root; `pub` at root (Flutter); and `github-actions` at root.

6. Rules-as-code testing (the primary authorization boundary)

Authorization is enforced by security rules, so the rules are tested like code against the Firebase Emulator Suite on synthetic data only:

- `functions/test/firestore.rules.test.js` (~4,100 lines) — the exhaustive Firestore rules matrix (positive and negative, cross-tenant, field-lock, query-scoping cases).
- `functions/test/security_poc.rules.test.js` — the security-assessment proof-of-concept + regression suite. Each test pairs a legitimate write that must keep working with the malicious write that must be denied, so a red test isolates to the vulnerability. It encodes the deployed fixes F-01, F-02, F-03 and a positive cross-tenant-isolation assurance test (a school-A teacher can neither read school-B data directly nor sweep it via an unconstrained collection-group query).
- `functions/test/storage.rules.test.js` — the Storage rules suite.

These run via `functions/package.json` scripts `test:rules` and `test:rules:storage` (both wrapped by `scripts/with-jdk21.sh`), and are wired into **both** the per-PR `demo-readiness` gate (§5.1) and the weekly `security-review` job (§5.3). A rules regression fails CI before it can merge.

7. Deploy gates

Only the admin portal auto-deploys. Everything else is a deliberate, human-run deploy — this is a known, documented property of the estate, not an oversight.

- **Admin portal (auto):** `.github/workflows/admin-deploy.yml` deploys `admin/` to Firebase Hosting on push to `main` (admin-affecting paths). It authenticates **keylessly** via GitHub OIDC / Workload Identity Federation (no JSON private key stored in GitHub), the WIF provider condition accepts only this repo's `main` branch, and the service-account binding is scoped to that principal. Before deploying it runs `infra/iam/audit-admin-build-identity.sh` to **refuse the deploy** if the build or runtime identity has drifted to a default account or gained project-data/secret/key access; after

deploying it disables the redundant Firebase Frameworks auth bridge (`scripts/security/disable-admin-firebase-framework-auth-bridge.sh`). Deploys are serialized (`concurrency: admin-deploy-main` , no cancel-in-progress).

- **School portal (manual):** `FIREBASE_CLI_EXPERIMENTS=webframeworks firebase deploy --only hosting:school` . Gate before deploy is `tsc --noEmit` + Next build (there is no lint CI on the portal); never run `next build` against a live `next dev` server.
- **Cloud Functions (manual):** `firebase deploy --only functions` . The Functions predeploy hook runs ESLint + `tsc` , so non-lint-clean merged code blocks the deploy — a de-facto gate.
- **Security rules / indexes (manual):** `firebase deploy --only firestore:rules` / `firestore:indexes` . Note: an index deploy silently **deletes** remote indexes missing from `firestore.indexes.json` , so the remote set is dumped and merged before deploying.
- **Flutter app (manual):** built via `./scripts/flutter-build.sh <target>` and released through the app stores.

Post-deploy, the release evidence checklist (§4) requires confirming that the reviewed rules/config match the **live deployment hashes** and recording a production canary.

8. Rollback

- **Rules / functions / portals:** roll back by re-deploying the previous known- good revision (the squash-merge history gives a clean revert point; the admin portal keeps Cloud Run revisions). Undoing one's own uncommitted work is done by explicit edit, never by destructive `git reset` / `checkout` on a shared checkout.
- **Feature-level rollback without deploy:** kill switches and entitlement flags are Firestore-doc-driven (e.g. `platformConfig/incrementalAggregation` , notification caps, the AI-eval gates), so a feature can be turned off by flipping a document with no code deploy. Feature-flag parity is CI-enforced (§5.2) so a switch cannot display a state the feature is not in.
- **MFA enforcement:** the mandatory admin-TOTP portal gate has an explicit short-lived emergency rollback (`ADMIN_TOTP_ENFORCED=false`), documented in `docs/ADMIN_TOTP_MFA_RUNBOOK.md` .

9. Findings and remediation loop

Findings from the automated scanners and the self-managed assessment are tracked in a single register — `docs/security/FINDINGS_REGISTER.md` — one row per finding with severity, ST4S mapping, status, owner and decision. Fixed findings carry a regression test (rules fixes → `security_poc.rules.test.js`) so the same class cannot silently regress. As of 2026-07-24 every fixable code-security finding (F-01–F-04, F-07, F-09/A2, SAST-01) is fixed, regression-tested, merged and deployed; the remainder are accepted-by-design, launch-gated, or upstream-tracked (see the register and `VULNERABILITY_ASSESSMENT_REPORT_2026-07-24.md`).

10. Supporting evidence index

Control	Evidence
Full regression gate	<code>.github/workflows/demo-readiness.yml</code> , <code>scripts/demo-readiness-local.sh</code>
Admin build/typecheck/flag-parity gate	<code>.github/workflows/admin-ci.yml</code>
Weekly automated security review	<code>.github/workflows/security-review.yml</code>
Secret scanning (history)	<code>.github/workflows/secret-scan.yml</code> , <code>.gitleaksignore</code>
SCA (osv-scanner)	<code>.github/workflows/sca-osv.yml</code>
SAST (semgrep)	<code>.github/workflows/sast-semgrep.yml</code>
Dependency updates	<code>.github/dependabot.yml</code>
Rules-as-code tests	<code>functions/test/firestore.rules.test.js</code> , <code>functions/test/security_poc.rules.test.js</code> , <code>functions/test/storage.rules.test.js</code>
Release review gate	<code>docs/privacy/RELEASE_PRIVACY_SECURITY_REVIEW.md</code>
Admin auto-deploy + identity guard	<code>.github/workflows/admin-deploy.yml</code> , <code>infra/iam/audit-admin-build-identity.sh</code>
Findings register / assessment	<code>docs/security/FINDINGS_REGISTER.md</code> , <code>docs/security/VULNERABILITY_ASSESSMENT_REPORT_2026-07-24.md</code>

11. Known gaps (for the reviewer)

- **Report-only scanners.** The osv-scanner and semgrep workflows currently run **monthly + on-demand only** and are report-only; their per-PR triggers are disabled pending action-ref / green-baseline verification. To claim these as a per-deploy blocking gate, the per-PR triggers must be re-enabled and made blocking. Until then, the blocking dependency gate is the weekly/PR `npm/pnpm audit` (production deps, high+) in §5.1/§5.3.
- **No lint CI on the school portal.** It is gated by `tsc` + Next build only (documented); a reviewer should confirm this is acceptable.
- **Manual deploys.** Because functions/rules/app are deployed by hand, the "reviewed config matches live hashes" release step (§4/§7) is the control that the deployed state matches what was reviewed — confirm this is being recorded for every release, not just at assessment time.

- **Approver identity.** The release gate names a "release approver" role; confirm the named human owner is recorded.



Lumi Reading · Security & Privacy Evidence

T1

Security Monitoring Plan

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT

ST4S item: T1 (risk-based, continuous monitoring) Version: 0.1 DRAFT · Date: 2026-07-24 Status: Draft for review — not yet signed

1. Purpose and scope

This plan describes how Lumi Reading continuously monitors for security vulnerabilities and operational failures, triages what it finds by risk, and schedules the periodic assessments (self-managed and external) that keep the picture current. It covers the Lumi-owned estate: the Flutter app, Cloud Functions, `packages/server-ops`, the two Next.js portals, the marketing site, and the security rules — all in `lumi-ninc-au` (`australia-southeast1`). It does **not** cover the vendors' own infrastructure (Google/Firebase, SendGrid, Twilio, Apple/Google stores, Open Library/Google Books); those are governed by the vendor register and monitored only through Lumi's configuration and use of them.

Monitoring is **risk-based**: findings are ranked by severity and blast radius, recorded in a single register, and worked in priority order (§5). It has four layers — automated scanning (§3), dependency management (§4), the self-managed assessment cadence (§6), and an independent external penetration test (§7) — plus operational health monitoring (§8).

2. Roles

- Security Lead (Nic / Director)**: owns this plan, the findings register, triage decisions and exceptions.
- Release approver**: enforces the per-release privacy/security gate (`docs/privacy/RELEASE_PRIVACY_SECURITY_REVIEW.md`).
- External tester (to be engaged)**: performs the annual independent penetration test (§7).

3. Automated vulnerability scanning — per-deploy and monthly

All scanners are CI workflows in `.github/workflows/` (see EV13 §5 for detail):

Scanner	What it covers	Cadence	Mode
<code>security-review.yml</code>	Functions unit tests, Firestore rules emulator suite, production dependency audit (<code>npm audit --omit=dev --audit-level=high</code> ; <code>pnpm audit --prod --audit-level high</code>)	Weekly (Mon 02:17 UTC) + on demand	Blocking
<code>demo-readiness.yml</code>	Full regression gate incl. Firestore + Storage rules emulator suites, Flutter suite, portal typecheck/security tests	Every PR + push to <code>main</code>	Blocking
<code>secret-scan.yml</code>	<code>gitleaks</code> over the complete git history (redacted)	Every push + every PR + on demand	Blocking
<code>sca-osv.yml</code>	<code>osv-scanner</code> over every lockfile (npm + pub), SARIF → Security tab	Monthly (1st, 03:17 UTC) + on demand	Report-only
<code>sast-semgrep.yml</code>	<code>semgrep</code> SAST (typescript/javascript/secrets rulesets), SARIF → Security tab	Monthly (1st, 03:23 UTC) + on demand	Report-only
<code>admin-ci.yml</code>	Admin typecheck/lint/build + feature-flag parity	Every admin PR + push to <code>main</code>	Blocking

This satisfies the "scan on every deployment and at least monthly" expectation: the dependency audit and rules/regression suites run on **every PR** (per-deploy) and again **weekly**; osv-scanner and semgrep run **monthly** and on demand. Scanner outputs land in the GitHub Security tab (SARIF) and are triaged into the findings register (§5).

Current gap (tracked): osv-scanner and semgrep are report-only with per-PR triggers disabled pending action-ref/baseline verification. The blocking dependency control today is the weekly/PR `npm/pnpm audit`. Re-enabling the per-PR SCA/SAST triggers and making them blocking is the intended end state.

4. Dependency management (SCA)

- Dependabot** (`.github/dependabot.yml`) opens weekly dependency PRs for npm (`/functions`, `/school-admin-web`, `/admin`, `/marketing-site`, root), pub (Flutter), and `github-actions`.
- osv-scanner** (§3) and the **weekly production** `npm/pnpm audit` (§3) cross-check the same tree.
- Open dependency risk is tracked as **SCA-01** in the register: nine transitive advisories (eight moderate, one high) under `firebase-admin`, with no clean upstream fix available (a forced upgrade breaks). Disposition: tracked, bump `firebase-admin` when a patched release lands; Dependabot + osv-scanner watch it. Patch deadlines and the patch process itself belong to the (separately drafted) EV12 Patch Management Process.

5. Risk-based triage — the findings register

The single source of truth is [docs/security/FINDINGS_REGISTER.md](#): one row per finding with a severity, ST4S mapping, status (open / in-progress / confirmed-unfixed / fixed+verified / accepted-by-design), owner and decision, plus a dated change log. It aggregates findings from the self-managed assessment, the mobile (AP2/MASVS) review, [npm/pnpm audit](#), osv-scanner and semgrep, de-duplicated against the closed dry-run findings ([PENTEST_DRYRUN_FINDINGS_2026-07-20.md](#)).

Triage rule: severity is reconciled against **current blast radius** (a control-bypass framing may be High while the live impact is Medium), and items are worked highest-first. Fixed findings must carry a regression test before being marked verified (rules fixes → [functions/test/security_poc.rules.test.js](#)); accepted risks must carry a written rationale (e.g. F-06 storage first-claim, F-08 SameSite CSRF). This is the T1 risk-based-triage evidence.

6. Self-managed assessment cadence (EV11 feeder)

Lumi runs a structured, source-code-assisted internal assessment against OWASP ASVS/WSTG, OWASP Top 10 (2025) + SANS CWE Top 25, and MASVS/MASTG for mobile, with all dynamic testing confined to the Firebase Emulator Suite on synthetic data (production is treated read-only). The current report is [docs/security/VULNERABILITY_ASSESSMENT_REPORT_2026-07-24.md](#) (EV11), with method in [SECURITY_ASSESSMENT_ORCHESTRATION_PLAN.md](#) and live status in [ASSESSMENT_STATUS.md](#).

Cadence:

Review	Frequency	Evidence
Automated Functions/rules/dependency review	Weekly + on demand	.github/workflows/security-review.yml
Full self-managed vulnerability assessment	At least annually, and before a major release or the ST4S full-assessment nomination	VULNERABILITY_ASSESSMENT_REPORT_*.md
Per-release privacy/security review	Every relevant PR/release; full review quarterly during beta	docs/privacy/RELEASE_PRIVACY_SECURITY_REVIEW.md
IAM keys/roles + deploy WIF review	Monthly + after deployment changes	IAM export + capability canaries
Vendor/subprocessor/APP 8 register	Quarterly + before new vendor use	Dated register approval
Breach tabletop	Six-monthly + after a material incident	Scenario/action record

The per-release and recurring schedule are defined authoritatively in the release-gate doc's "Recurring schedule" table; this plan references rather than duplicates it.

7. Independent external penetration test (annual)

An independent external penetration test is planned **annually** and provides the EV10 evidence.

- **Status:** OUTSTANDING. The scoping pack — [docs/security/PENETRATION_TEST_SCOPING_PACK.md](#) — is ready: it defines in-scope targets (both portals, the marketing lead forms, Firestore/Storage rules as the primary boundary, ~60 Cloud Functions, Auth/App Check, the AI comprehension pipeline, and optional mobile MASVS), out-of-scope items, the no-real-child-data constraint, a grey-box approach (rules provided to the tester), OWASP ASVS/WSTG + MASVS methodology, required deliverables (executive summary, per-finding ratings, a redacted shareable report, and a re-test), and the rules-of-engagement to be finalised in the SOW.
- **Next steps** (from the pack §9): send the RFQ ([PENETRATION_TEST_RFQ_EMAIL.md](#)) to CREST-accredited AU firms, stand up the staging project with seeded role accounts, sign the SOW, schedule, then remediate → re-test → file the redacted report as EV10.
- Until the external test lands, the self-managed report (§6) stands as the **interim** vulnerability-assessment evidence (EV11).

8. Operational health monitoring

Security depends on the backend actually running, so operational health is monitored continuously:

- **Cron heartbeats + storage metrics** are written to the [opsMetrics](#) collection (deny-all to clients); the admin dashboard polls them, and threshold alert policies are attached to both security email channels.
- [scripts/audit-function-health.sh](#) is a read-only, one-shot audit of the Gen2 Functions estate that catches the silent-failure classes: per-service invoker-403s, missing [run.invoker](#) bindings on trigger/scheduler-backed services, dropped events (maxInstances saturation), scheduler jobs whose last attempt failed, and cron heartbeats that are missing/errored/stale beyond their cadence. It **auto-runs** via a committed PostToolUse hook after a functions deploy or a gcloud IAM change, and is run by hand after infra changes made outside the repo.
- The most recent operations audit ([docs/security/OPERATIONS_HEALTH_AUDIT_2026-07-17.md](#)) recorded backups (7-day PITR + deletion protection, restore drill matched production counts), dedicated runtime identities, 13 enabled alert policies on both channels, and a repaired Scheduler identity drift — a concrete instance of this monitoring catching a live 403 fault.

9. Consolidated cadence

Activity	Frequency	Owner	Evidence
Regression + rules + dependency-audit CI	Every PR / push to <code>main</code>	CI	EV13 §5 workflows
Secret scan (full history)	Every push / PR	CI	<code>secret-scan.yml</code>
Weekly automated security review	Weekly	CI / Security Lead	<code>security-review.yml</code>
SCA (osv-scanner) + SAST (semgrep)	Monthly + on demand	Security Lead	<code>sca-osv.yml</code> , <code>sast-semgrep.yml</code>
Dependency-update PRs	Weekly	Dependabot / Security Lead	<code>dependabot.yml</code>
Function-health audit	After each functions deploy / IAM change + on demand	Security Lead	<code>scripts/audit-function-health.sh</code>
Self-managed vulnerability assessment	Annually + pre-major-release	Security Lead	<code>VULNERABILITY_ASSESSMENT_REPORT_*.md</code>
External penetration test	Annually	External tester	<code>PENETRATION_TEST_SCOPING_PACK.md</code> → EV10 (pending)
IAM / vendor / PIA / tabletop	Monthly / quarterly / six-monthly	Security Lead	release-gate schedule table

10. Known gaps (for the reviewer)

- **EV10 external test is not yet done** — the scoping pack is ready but no firm is engaged. This is the single largest outstanding monitoring input; §7 tracks it.
- **SCA/SAST are report-only and monthly**, not per-PR blocking (§3). Confirm the intended end state and whether monthly is sufficient for T1 in the interim.
- **Alert-delivery receipt** (that a synthetic alert reaches both inboxes) and **named incident roles** are open human items in the operations audit — verify these are closed.
- **Cadence ownership**: the plan names the Security Lead as owner throughout; confirm the named human and that the annual/monthly reviews are actually calendared, not just documented.



Lumi Reading · Security & Privacy Evidence

T2 / T3

Patch & Vulnerability Management

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT

ST4S item: EV12 (patch management), also evidences T2 (centrally managed patching) and T3 (timely remediation of known-exploited vulnerabilities)
Version: 0.1 DRAFT · **Date:** 2026-07-24 **Status:** Draft for review — not yet signed

1. Purpose and scope

This document describes how Lumi Reading learns about vulnerable dependencies, platforms and tooling; how it prioritises and applies patches; and how it verifies that a patch was applied and stays applied. Every automated control described is implemented in the repository and cited by file path. Where a deadline is a policy target rather than an evidenced-as-met fact, it is called out (see §9).

Scope: the Lumi monorepo (`lumi-ninc-au` , `australia-southeast1`) — the Flutter app (`lib/**` , `pubspec.lock`), Cloud Functions (`functions/**`), the privileged core (`packages/server-ops/**`), the two Next.js portals (`school-admin-web/` , `admin/`), the marketing site (`marketing-site/`), the CI workflows (`.github/workflows/**`), and the developer endpoint (the macOS build machine). It does **not** cover the managed platforms Lumi builds on — Firebase / Google Cloud, SendGrid, Twilio, the app stores — which are patched by the vendor and tracked through the vendor register, not this process.

2. Principles

- **Central management (T2).** Dependency updates are driven centrally by configuration in the repository (`.github/dependabot.yml`), not by ad-hoc manual bumps. Every update lands as a reviewed pull request through the same branch → PR → CI → squash-merge flow as any other change (see EV13 §3), so a patch is peer-reviewed and passes the full regression gate before it reaches `main` .
- **Detect, decide, verify.** Every advisory is triaged to a decision — patch, accept-with-rationale, or defer-and-track — recorded in the findings register, and (for applied patches) verified by re-running the audit that surfaced it.
- **Risk-based deadlines.** Remediation time is driven by severity and by whether the vulnerability is being actively exploited (§5).

3. Sources watched

Source	What it tells us	How it reaches us
GitHub security advisories / Dependabot alerts	Known-vulnerable versions of a dependency in our lockfiles	Dependabot alerts on the repo + weekly update PRs (<code>.github/dependabot.yml</code>)
<code>npm</code> / <code>pnpm</code> audit database	Advisories affecting the resolved dependency tree	Weekly <code>security-review.yml</code> job + per-PR release gate (§4.2)
OSV database (Google)	Cross-ecosystem advisories over npm and pub lockfiles	<code>sca-osv.yml</code> , SARIF → GitHub Security tab (§4.3)
Firebase / Google Cloud release notes	Runtime deprecations (e.g. Node 20 decommission), SDK security fixes	Manual review by the security lead; migrations tracked as work items
Flutter / Dart release notes	Pinned-toolchain security fixes (<code>flutter</code> is pinned to 3.44.6 in CI)	Manual review; pub updates arrive via Dependabot
Node.js release notes	Runtime EOL / security releases (functions run Node 22)	Manual review; CI pins Node 22
macOS / endpoint updates	OS and Xcode/CLI security updates on the build machine	macOS automatic security updates; formal device standard is pending (§9)

4. Automated tooling (cited)

All automation lives in `.github/` . Detail on triggers and enforcement is in EV13 §5; the patch-relevant behaviour is summarised here.

4.1 Dependabot — update automation (`.github/dependabot.yml`)

Weekly grouped update PRs for:

- **npm** in `/functions` , `/school-admin-web` , `/admin` , `/marketing-site` and the repo root (each capped at 5 open PRs, `minor` + `patch` grouped to reduce noise);
- **pub** at the root (the Flutter app);
- **github-actions** at the root (grouped as one).

Grouping means routine minor/patch bumps arrive as a small number of reviewable PRs; a major or security bump that Dependabot cannot group surfaces on its own.

4.2 Weekly dependency audit (`.github/workflows/security-review.yml`) — blocking

Scheduled Mondays 02:17 UTC (`cron: "17 2 * * 1"`) plus manual dispatch. Runs a **production** dependency audit on the security-relevant surfaces:

- Functions — `npm audit --omit=dev --audit-level=high` ;
- Portals — `pnpm audit --prod --audit-level high` .

The same production audits are part of the per-release evidence checklist (`docs/privacy/RELEASE_PRIVACY_SECURITY_REVIEW.md`), so an accepted critical/high in a production dependency blocks a release unless a named, time-limited exception is recorded. This is the **blocking** dependency gate today.

4.3 OSV software-composition analysis (`.github/workflows/sca-osv.yml`)

`osv-scanner` (Google action v2) run **recursively over every lockfile** (npm + pub), uploading SARIF to the GitHub Security tab. Scheduled monthly (`cron: "17 3 1 * *"`) plus manual dispatch. **Report-only** (`continue-on-error`) while the findings register is triaged; the per-PR trigger is deliberately disabled pending action-ref verification (documented inline in the workflow). This widens coverage beyond the prod-only, high-only weekly audit (it also sees pub and dev-tree advisories).

4.4 Secret scanning (`.github/workflows/secret-scan.yml`) — blocking

`gitleaks` v8.30.1 over the **complete git history** (`fetch-depth: 0` , `--redact=100`), on every push to `main` , **every** pull request, and on demand. This is the control that a patch PR (or any PR) does not introduce a leaked credential; the current history is gitleaks-clean.

5. Severity and remediation deadlines (T3)

Deadlines are measured from the date the advisory is triaged (first appears in an audit/scan or a Dependabot alert) to the date the fix is merged to `main` .

Class	Target time to patch
Actively exploited (known-exploited / in-the-wild, any severity)	48 hours — treat as an incident; if no clean patch exists, apply a mitigation/workaround (kill switch, config, WAF/rule change) within the window and track the permanent fix
Critical / High advisory affecting a production dependency	14 days
Moderate	Next scheduled dependency cycle (≤30 days), or with the next release touching that surface
Low / informational	Tracked in normal security work; no fixed SLA

Where no clean upstream fix exists within the deadline, the item is **not** silently allowed to lapse: it is recorded as *deferred-and-tracked* in the findings register with a written rationale, a compensating control where available, and the trigger that will close it (a patched upstream release). The worked example in §7 is exactly this case.

6. Verification — applied, and stays applied

A patch is only considered done when it is verified, and re-verified on an ongoing basis so it cannot silently regress:

- **Applied.** The dependency bump changes the committed lockfile (`package-lock.json` / `pnpm-lock.yaml` / `pubspec.lock`); the PR passes the full regression gate (`demo-readiness.yml`) before merge; the release evidence checklist confirms the production audit is clean (or the exception is recorded) before the change is deployed.
- **Stays applied.** The weekly `security-review.yml` audit (§4.2) and the monthly `sca-osv.yml` scan (§4.3) re-run against the current tree, so a regression (a transitive downgrade, a re-introduced vulnerable version) resurfaces as a fresh finding rather than being assumed fixed. Dependabot continues to alert on any newly-published advisory affecting the pinned versions.
- **Recorded.** The disposition of each advisory is entered in the patch register (§8) and, for security findings, in `docs/security/FINDINGS_REGISTER.md` .

7. Worked example — SCA-01 (`firebase-admin`) transitive advisories)

The one open dependency finding demonstrates the deferred-and-tracked path.

- **Finding (SCA-01, `docs/security/FINDINGS_REGISTER.md`):** the Functions tree carries **9 transitive advisories (8 moderate, 1 high)** pulled in under `firebase-admin` — via `@google-cloud/firestore` → `google-gax` ; `@google-cloud/storage` → `teeny-request` → `uuid` ; and `retry-request` .
- **Decision:** *deferred-and-tracked*. There is **no clean upstream fix** — a forced upgrade (`npm audit fix --force`) breaks the build, because the vulnerable packages are pinned by `firebase-admin` 's own dependency ranges, not by Lumi's direct dependencies. Forcing them would diverge from a supported `firebase-admin` release.
- **Compensating position:** the advisories are transitive and none is flagged as actively exploited; the affected code paths are server-side (Admin SDK), not client-reachable.
- **Trigger to close:** bump `firebase-admin` when a release lands that resolves the ranges. Dependabot (§4.1) and `osv-scanner` (§4.3) both watch this tree, so the patched release will surface automatically as an update PR / cleared finding.
- **Register linkage:** tracked as SCA-01 (mapped to ST4S T2/T3/AP1/EV11) with a dated change-log entry.

8. Patch register (template)

The patch register is the running record of every advisory and its disposition. It is a superset view of the dependency rows already in the findings register, formatted for the T2/T3 evidence. Template:

Advisory (ID / link)	Package (+ path)	Severity	Exploited?	Decision (patch / accept / defer)	Applied date	Verified (date + how)	Notes / trigger to close
GHSA-... / OSV-...	<code>pkg@ver (/functions)</code>	High	No	Patch	2026-07-...	2026-07-... — <code>npm audit</code> clean + CI green	—
SCA-01 (register)	<code>firebase-admin</code> transitive (<code>/functions</code>)	High/Mod	No	Defer + track	—	Weekly audit + osv-scanner watching	Bump <code>firebase-admin</code> when patched release lands

Column notes: **Applied date** is the merge-to-`main` date; **Verified** records the audit/scan that confirmed the fix and the date it last passed; a *defer* row stays open with its close-trigger until the patched release lands.

9. Endpoint / OS patching

The developer/build endpoint (macOS) receives Apple's automatic security updates; Xcode and command-line toolchains are updated when a build requires or a security release warrants it. A **formal device standard (ST4S A10)** — the enumerated macOS security settings and update posture — is a separate document that is not yet drafted (kickoff backlog). Until it is signed, endpoint patching is asserted here only as "automatic OS security updates enabled"; the full standard must not be read as in force.

10. Supporting evidence index

Control	Evidence
Central update automation	<code>.github/dependabot.yml</code>
Weekly production dependency audit (blocking)	<code>.github/workflows/security-review.yml</code>
SCA over all lockfiles (npm + pub)	<code>.github/workflows/sca-osv.yml</code>
Secret scanning on every PR/push	<code>.github/workflows/secret-scan.yml</code>
Full regression gate that a patch PR must pass	<code>.github/workflows/demo-readiness.yml</code> , <code>scripts/demo-readiness-local.sh</code>
Release evidence checklist (audit must be clean)	<code>docs/privacy/RELEASE_PRIVACY_SECURITY_REVIEW.md</code>
Findings register (incl. SCA-01 disposition)	<code>docs/security/FINDINGS_REGISTER.md</code>
Vulnerability assessment (context)	<code>docs/security/VULNERABILITY_ASSESSMENT_REPORT_2026-07-24.md</code>

11. Known gaps (for the reviewer)

- **Deadlines vs practice.** §5 sets the 14-day (Critical/High) and 48-hour (actively-exploited) targets as policy. Confirm these are actually being **met and recorded** in practice — the register must show real applied/verified dates against real advisories, not just the SLA text.
- **Named owner.** This process names "the security lead" throughout; confirm the named human responsible for triaging advisories and driving patches within the deadlines is recorded (this is the same role as EV13 §11 / the monitoring plan's Security Lead — likely Nic / Director, to be confirmed and signed).
- **Register cadence.** Decide and record how often the patch register is reviewed and reconciled (proposed: weekly, aligned to the Monday `security-review.yml` run), and who signs off the review.
- **Report-only SCA.** `sca-osv.yml` is monthly and report-only with its per-PR trigger disabled (§4.3). The blocking dependency control today is the weekly/PR `npm/pnpm audit` (prod deps, high+). Re-enabling the per-PR SCA trigger and making it blocking is the intended end state; confirm whether monthly is sufficient in the interim.
- **Device standard (A10).** Endpoint/OS patching (§9) is asserted only as "automatic OS security updates on"; the formal macOS device standard is not yet drafted or signed.
- **Sign-off.** This process requires Nic's sign-off before it is the governing document.



Incident Response Plan

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT

ST4S item: EV9 (incident response plan + register), also evidences T6 (incident register) and T7 (data-breach / customer notification) **Version:** 0.1 DRAFT
Date: 2026-07-24 **Status:** Draft for review — not yet signed

1. Purpose and scope

This plan defines how Lumi Reading detects, responds to, contains, eradicates, recovers from and learns from a security or privacy incident, and how it decides and executes notification to affected schools/individuals and the OAIC. It uplifts the existing data-breach response plan and tabletop record ([docs/privacy/DATA_BREACH_RESPONSE_AND_TABLETOP.md](#)) into a full incident response procedure with an incident register. Where a control or appointment is pending, it is called out (see §11).

Scope: a suspected or confirmed compromise of the confidentiality, integrity or availability of Lumi personal information or systems — the Flutter app, Cloud Functions, ([packages/server-ops](#)), the two Next.js portals, the marketing site, the security rules, and the data held in ([lumi-ninc-au](#)) ([australia-southeast1](#)). This document is a procedure, not legal advice; the incident lead must obtain Australian privacy/legal advice when a breach may cause serious harm or a notification decision is uncertain.

The structure follows the OAIC's data-breach preparation-and-response guidance, as does the source plan.

2. Roles and authority

Named appointments are recorded authoritatively in ([docs/privacy/DATA_BREACH_RESPONSE_AND_TABLETOP.md](#)) §1 (roles table). While Lumi is small, one person may hold several roles, but **every action must be recorded** (§10 register).

Role	Responsibility	Holder
Incident lead	Declare severity, coordinate, preserve timeline, approve containment	Nic (Director); authorised backup named in the breach-response plan
Technical lead	Containment, evidence, eradication, recovery, verification	Nic (Director); backup coordinates approved technical assistance
School liaison	Verify school authority; coordinate affected-school communication	Nic (Director) / backup
Communications	Clear, child-safe notices; no speculation	Nic (Director) / backup
Scribe	Time-stamped decisions, evidence chain, action list	Nic (Director) until delegated
Privacy / legal lead	NDB assessment, regulator liaison, school/individual notice	Unappointed — external Australian privacy counsel required

The incident lead is authorised to disable a feature, revoke credentials or sessions, block a deployment, enforce maintenance mode, suspend a school, or temporarily stop processing to protect people. **Destructive evidence deletion is not authorised.**

Formal appointment (GO1/GO2). The named security-officer (GO1) and privacy-officer (GO2) appointment letters that formally back these roles are drafted but **pending signature** ([docs/security/ASSESSMENT_STATUS.md](#) records GO1/GO2 as *Not Ready*). The operational role assignments above are already confirmed in the breach-response plan; the signed officer letters are the outstanding governance artefact (§11).

3. Detection and reporting

An incident can be raised from any of these channels:

- **Automated operational alerts.** Cron-heartbeat and storage-usage metrics are written to the ([opsMetrics](#)) collection (deny-all to clients); threshold alert policies are attached to **two separate security-alert inboxes** (a primary operational address and an independent backup), and the admin dashboard polls the metrics. Delivery to both inboxes was verified in the tabletop (a synthetic Cloud Monitoring incident reached both). See the monitoring plan §8 and ([docs/security/OPERATIONS_HEALTH_AUDIT_2026-07-17.md](#)).
- **Function-health audit.** ([scripts/audit-function-health.sh](#)) catches silent backend failures (invoker-403s, dropped events, failed crons, stale heartbeats); it auto-runs after a functions deploy or IAM change.
- **Security-scan findings.** Escalated from the CI scanners / findings register (EV13 §5, monitoring plan §5) when a live-exploitable issue is found.
- **External reports.** A researcher or member of the public reports via the privacy/support intake mailbox recorded in the breach-response plan ([support@lumi-reading.com](#) , owner-confirmed monitored daily + MFA-protected).
- **Firestore Data Access audit logging** ([DATA_READ](#) / [DATA_WRITE](#)) is enabled project-wide, so a suspicious access pattern leaves evidence even below the cost threshold that ordinary metrics would surface.

On report: the receiver records UTC + local time, reporter, observable symptoms and an incident ID, and notifies the incident lead. For a SEV-1 the backup lead is notified within 15 minutes (§4).

4. Triage and severity

Severity drives response speed and is re-assessed as scope becomes clear ([docs/privacy/DATA_BREACH_RESPONSE_AND_TABLETOP.md](#) §2).

Severity	Example	Initial response target
SEV-1 Critical	Confirmed cross-school/child exposure, stolen privileged credential, public Storage, destructive compromise	Begin immediately; notify backup lead within 15 min
SEV-2 High	Likely unauthorised access with limited scope, deletion failure leaving data accessible, suspicious impersonation	Begin within 30 min
SEV-3 Medium	Blocked attack, contained non-production leak, incorrect adult-only email	Same business day
SEV-4 Low	No personal-data or control impact	Track in normal security work

5. Containment

Protect people first: stop the affected feature or tenant if the exposure is ongoing. Revoke exposed keys, sessions, tokens and signed URLs **without** destroying evidence. Preserve the relevant Cloud Audit, Cloud Run, Firebase, GitHub/deployment and application audit records with restricted access. The event-specific safe actions are the technical containment map ([docs/privacy/DATA_BREACH_RESPONSE_AND_TABLETOP.md](#) §5), summarised:

Event	Immediate safe actions
Firestore Rules regression	Roll back to last reviewed ruleset; suspend affected client version; compare active rules hash; add negative test
Storage exposure / signed-URL leak	Restore Storage Rules/IAM; revoke signer capability; replace exposed object generations; inspect egress
Service-account / API-key leak	Disable first, verify healthy ADC/WIF path, delete key, restrict API key, inspect Cloud Audit Logs
Compromised user / session	Disable Auth user, revoke refresh tokens, remove sessions/impersonation, verify memberships
Audio/AI vendor incident	Set feature kill switch off, stop the queue/worker, preserve minimum job metadata, request provider containment/deletion evidence
Deletion-workflow failure	Keep the job resumable, stop unsafe destructive retries, inventory expected records, repair and rerun idempotently
Malicious / risky release	Activate force-update/support mode, halt rollout, revert backend compatibility if needed

Feature-level containment without a deploy is available: kill switches and entitlement flags are Firestore-doc-driven (EV13 §8), so an affected feature can be turned off by flipping a document.

6. Eradication

- Establish and fix the **root cause**; add a regression test that fails on the vulnerability before it is closed (rules fixes → [functions/test/security_poc.rules.test.js](#)).
- Rotate any credential, key or session that was, or may have been, exposed; confirm the healthy keyless (WIF/ADC) path before deleting a leaked key.
- Confirm no residual foothold (impersonation grants, orphaned sessions, altered membership/role documents, injected data).

7. Recovery

- Restore service only after verifying deployed **rules/config/code hashes**, runtime IAM, App Check state, API-key restrictions, Storage access and affected data integrity against the reviewed known-good baseline.
- Re-run the cross-tenant negative tests (Firestore Emulator matrix) and a production synthetic-denial probe against the restored state.
- Confirm alerts again reach both security inboxes.
- Back-out data recovery uses backups / PITR (7-day PITR + deletion protection; a restore drill matched production counts — [docs/security/OPERATIONS_HEALTH_AUDIT_2026-07-17.md](#)). Note: a Firestore document deletion does **not** instantly purge PITR versions; record when inaccessible backup/PITR data ages out.

8. Notification — customers and OAIC (T7)

Notification is a **legal assessment**, **not a record-count threshold**, and is led by the privacy/legal lead (currently unappointed → external Australian counsel must be engaged, §11).

- Schools.** Notify affected schools through a **separately verified emergency contact** (contract/CRM), never a possibly-compromised in-app account. A holding notice template is in the source plan §7.
- Individuals + OAIC (NDB scheme).** If there are reasonable grounds to believe an **eligible data breach** has occurred — unauthorised access/disclosure or likely loss, **likely serious harm**, and inability to prevent that harm by remedial action — prepare the OAIC statement and notify

affected individuals in the legally appropriate way. A **suspected** eligible breach triggers a prompt assessment (the OAIC's 30-day expeditious-assessment expectation); the assessment must not be allowed to silently drift beyond the statutory period.

- **Content of notices.** What happened, what information was involved, the practical risks, containment already taken, what people should do, and how to get support — in plain, child-safe language, with no speculation.
- **Coordination.** Time notification with law enforcement / cyber-insurer / providers only where relevant; document any delay and its authority.

Harm assessment must weigh child-specific risks: identity fraud, physical safety, humiliation, discrimination, educational harm, family conflict, and risk created by a child's voice or location.

9. Communications and workarounds

- **In-app status banner.** When users must be told something out-of-band (e.g. a Firebase outage or an enforced maintenance window), the operator publishes a banner via the Cloudflare status worker — runbook `docs/status-messages.md`, helper `scripts/status-message.sh` — with `info` / `warn` / `critical` severity (critical is non-dismissible).
- **Force-update / support mode** halts a malicious or unsafe app version and points users at a safe build.
- All external wording is child-safe and speculation-free; the holding-notice template is the starting point.

10. Incident register (T6)

Every incident is recorded in a standing incident register held **outside** the production systems and the ordinary support inbox, in a dedicated access-restricted location (§ evidence handling, source plan §4). The register carries every T6 field:

#	Incident ID	Date occurred	Date discovered	Severity	Description	Actions taken (containment → recovery)	Person / authority reported to	Notification decision (schools / individuals / OAIC)	Status	Post-incident review date
1	INC-2026-...	(UTC + local)	(UTC + local)	SEV-...	...	...	...	...	Open/Closed	...

Field notes: **Date occurred** and **date discovered** are recorded separately (they are frequently different); **actions taken** is the running timeline the scribe maintains; **person/authority reported to** captures internal escalation *and* any external report (school emergency contact, OAIC, law enforcement, insurer). Evidence is hashed on export, with collector/source/UTC-time/transfer recorded; tokens, keys, raw cookies and child recordings are never printed to a transcript (source plan §4).

As of this draft the register holds no real incidents — only the tabletop walkthrough (§12). It must be stood up as a live document at the location the breach-response plan designates (§14).

11. Post-incident review

A **blameless review** is held within five business days of containment: root cause, what worked, what didn't, lessons, owners and deadlines; update the PIA, vendor register, threat model and school FAQ as needed. Fixed root causes carry a regression test before service is restored (§6).

12. Tabletop exercise on record

A desk-based technical walkthrough was run **17 July 2026** (`docs/privacy/DATA_BREACH_RESPONSE_AND_TABLETOP.md` §6): a broad Firestore Rules change lets a School-A teacher query School-B reading logs for two hours; ~500 child records (names, book titles, minutes, optional comments) reportedly seen. The walkthrough exercised SEV-1 declaration, rules rollback, evidence preservation, cross-tenant negative testing, scoped data inventory, verified school contact, NDB assessment start, holding notice, and a five-day review.

Result: the process is technically executable. Closed during the exercise: alert delivery to both inboxes, operational role assignment (incident/technical leads), Firestore Data Access audit logging. Left open: verified per-school emergency contacts (not in the repo), an appointed external privacy/legal lead, and store-attested App Check. The exercise explicitly did **not** prove that an NDB notification decision has been legally reviewed.

13. Supporting evidence index

Control	Evidence
Source breach-response plan + tabletop record	<code>docs/privacy/DATA_BREACH_RESPONSE_AND_TABLETOP.md</code>
Operational alerts / dual inboxes / backups	<code>docs/security/OPERATIONS_HEALTH_AUDIT_2026-07-17.md</code> , monitoring plan §8
Function-health audit	<code>scripts/audit-function-health.sh</code>
Rules-regression rollback + regression test	<code>functions/test/security_poc.rules.test.js</code> , EV13 §8
Feature kill switches (containment without deploy)	EV13 §8
Status-banner comms runbook	<code>docs/status-messages.md</code> , <code>scripts/status-message.sh</code>
Release-hash verification (recovery)	<code>docs/privacy/RELEASE_PRIVACY_SECURITY_REVIEW.md</code>
Officer-appointment status (GO1/GO2)	<code>docs/security/ASSESSMENT_STATUS.md</code>

14. Known gaps (for the reviewer)

- **GO1/GO2 letters need signing.** The named security-officer and privacy-officer appointment letters are drafted but **pending signature**; until signed, the formal governance behind the roles in §2 is incomplete.
- **Privacy/legal lead unappointed.** The NDB-assessment / OAIC-liaison role has no appointed holder — external Australian privacy counsel must be engaged, and the notification timelines in §8 confirmed against OAIC obligations with that adviser. Do not read this plan as asserting an NDB decision capability in-house.
- **Incident register stood up.** §10 provides the template; confirm the live register exists at the designated access-restricted location, is reviewed on a set cadence, and that a named owner keeps it.
- **School emergency-contact register.** Verified per-school emergency contacts are **not** in the repository (a tabletop gap). Notification (§8) depends on this existing in the contract/CRM.
- **App Check (F-05).** Store-attested client attestation is **not yet enforced** (launch-gated); it would reduce scripted exploitation but does not correct broken authorisation. Noted so the plan is not read as claiming it.
- **Sign-off.** This plan requires Nic's sign-off (and privacy-adviser review of §8) before it is the governing document.



Business Continuity Plan

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT

ST4S item: EV7 (business continuity plan) **Version:** 0.1 DRAFT · **Date:** 2026-07-24 **Status:** Draft for review — not yet signed

1. Purpose and scope

This plan describes how schools keep operating when Lumi Reading is degraded or unavailable, how Lumi communicates during a disruption, and the order in which service is restored. It is the availability counterpart to the disaster-recovery plan

([docs/security/evidence/EV8_DISASTER_RECOVERY_PLAN.md](#) , which covers data loss/corruption and the technical restore) and the incident-response plan ([docs/security/evidence/EV9_INCIDENT_RESPONSE_PLAN.md](#) , which covers security incidents). Where a target is an expectation rather than a measured, drilled figure, it is called out (§10).

Scope: a loss or serious degradation of the availability of Lumi to schools, teachers, parents or children — whether caused by the underlying platform (Firebase / Google Cloud, [australia-southeast1](#)), by a Lumi change (a bad deploy or rules regression), or by a dependency (the app stores, SendGrid, Twilio, the status worker). Security incidents are in scope of this plan only for their availability impact; their handling is governed by EV9.

2. What "continuity" means for Lumi

Lumi is a supplementary reading-tracking tool, not a system a school depends on minute-to-minute to run its day. The continuity objective is therefore:

1. **no loss of a child's reading data** during an outage (the data-integrity objective — met primarily by on-device capture, §4, and by the backups in EV8); and
2. **a fast return to normal logging and visibility**, with clear communication while service is impaired.

Most of Lumi's availability is **inherited** from Google Cloud / Firebase, which Lumi cannot itself restore; Lumi's continuity actions are (a) preserving data at the edge so an outage does not destroy work, (b) communicating out-of-band, and (c) restoring Lumi's own code/config quickly when Lumi is the cause.

Key dependency note: the in-app status banner is served by an **independent Cloudflare worker**, deliberately *not* on Firebase, so it can still reach users during a Firebase outage (§5). This independence is a designed continuity property ([docs/status-messages.md](#)).

3. Disruption scenarios

Scenario	Primary effect	Lumi's continuity response
Platform (Firebase/GCP) outage	App can't sync; portals down	Reading still captured on-device (§4); publish status banner (§5); monitor Google status; restore follows Google
Lumi-caused outage (bad deploy, rules regression)	Feature broken or access denied/over-permissive	Roll back to last known-good revision/ruleset; feature kill switch where applicable; status banner; this is also an EV9 event if security-relevant
Malicious / unsafe app release	Bad client version in the field	Force-update / support mode via minimum-version policy points users at a safe build (§5)
Dependency outage (SendGrid, Twilio, app store)	Emails/SMS/onboarding delayed	Core logging unaffected; degrade the dependent feature; communicate if user-visible
Status-worker outage	Can't publish a banner	Fall back to direct school email (§5); clients keep their last cached banner and fail safe

4. Keeping schools operating during an outage

- **On-device reading capture (primary continuity control).** The app persists its working data locally (offline caches for students, reading logs and a pending-sync queue), so a child's reading can still be logged while Lumi's backend is unreachable; queued entries sync when service returns. This is the behaviour the outage status message promises users ("your reading still saves locally", [docs/status-messages.md](#)). On a cold start with no cached policy and a transient transport failure, the app continues into itself and retries (2/5/15/30/60 s) rather than blocking.
- **Manual / paper fallback (extended outage).** If Lumi is unavailable for an extended period beyond on-device buffering, schools revert to their existing paper reading-diary practice (the pre-Lumi norm) and staff re-enter the totals once service is restored. Note the accountability constraint: parents cannot backdate reading in the app by design, so post-outage catch-up of paper records is entered by teachers/staff, not retro-dated by parents (see [docs/CLASSROOM_BETA_READINESS_REVIEW.md](#)).
- **Read-only visibility degrades gracefully.** Dashboards/reports and non-essential features (comprehension AI evaluation, notifications, awards) are allowed to degrade or pause first; they are not required for a child to keep reading and being logged.

5. Communication channels

- **In-app status banner (all users, out-of-band).** The operator publishes a banner via the Cloudflare status worker using `scripts/status-message.sh`, at `info` / `warn` / `critical` severity (critical is non-dismissible); the client polls at ≤60 s. Runbook: `docs/status-messages.md`. Typical outage workflow: confirm the outage → publish a `warn` ("Lumi is having trouble — your reading still saves locally.") → escalate to `critical` if needed → `clear` on resolution → optional post-mortem `info`.
- **Force-update / support mode.** The `minAppVersion` policy can block an unsafe client version behind an update screen and point users at a safe build; a malformed policy fails *into* support mode (fail-safe).
- **Direct school communication.** For anything a school must act on (or if the status worker itself is down), schools are contacted through a **separately verified emergency contact** held in the contract/CRM — never assumed to be a possibly-affected in-app account (this register is the same one EV9 depends on; it is a known gap, §11).
- **Wording discipline.** All external messages are plain, child-safe and speculation-free (shared with the EV9 communications rules).

6. Recovery priorities

Restore in this order; never trade a security regression for availability:

1. **Confidentiality and integrity of child data** — a fix must not reopen a tenant-isolation or access-control gap (verified against the reviewed known-good baseline, EV9 §7).
2. **Reading-log capture and sync** — the core school workflow; drain the on-device pending-sync queue safely.
3. **Parent/teacher visibility** — dashboards and reports.
4. **Administrative functions** — portal provisioning, allocations, onboarding.
5. **Enhancement features** — AI comprehension evaluation, notifications, awards (these degrade first and restore last).

7. Target recovery expectations

These are **operating targets**, not drilled guarantees (§10), and are bounded by the platform's own restoration for a Google-side outage:

Objective	Target
Publish an in-app status banner after a confirmed user-visible outage	within ~30 min
Notify affected schools' emergency contacts (if action needed)	same business day
Roll back a Lumi-caused outage (deploy/rules) to last known-good	within the deploy/rollback window (EV13 §8)
Data-loss recovery point / restore time (RPO / RTO)	see EV8 (PITR 7-day window; RTO/RPO targets there)
Platform (Google-side) outage	recovery follows Google Cloud restoration; Lumi communicates and resyncs

8. Roles

Continuity is run by the same small team as incident response (EV9 §2): the Security/Technical Lead (Nic, Director) decides on rollback, kill switches, status-banner publication and force-update; the same person coordinates school communication via the verified emergency contact until delegated. Every action is recorded (shared with the EV9 register where the disruption is also an incident).

9. Testing and review

- This plan is reviewed at least annually and after any significant disruption.
- The status-banner path is exercised in practice (the runbook documents the real outage workflow); the data-restore path is exercised via the DR drill (EV8 §7).
- A combined continuity/DR walkthrough should be run on the same cadence as the security breach tabletop (`docs/privacy/DATA_BREACH_RESPONSE_AND_TABLETOP.md`) — see the gap in §11.

10. Supporting evidence index

Control	Evidence
In-app status banner (independent of Firebase)	<code>docs/status-messages.md</code> , <code>scripts/status-message.sh</code> , Cloudflare status worker
On-device offline capture + pending-sync queue	app offline caches (students / reading_logs / pending_sync); <code>docs/status-messages.md</code> cold-start behaviour
Force-update / support mode	<code>minAppVersion</code> policy (<code>docs/status-messages.md</code>)
Rollback / feature kill switches	<code>docs/security/evidence/EV13_SECURE_SDL_C.md</code> §8
Data recovery (RTO/RPO, backups, restore)	<code>docs/security/evidence/EV8_DISASTER_RECOVERY_PLAN.md</code>
Incident handling (security disruptions)	<code>docs/security/evidence/EV9_INCIDENT_RESPONSE_PLAN.md</code>
No-backdating accountability constraint	<code>docs/CLASSROOM_BETA_READINESS_REVIEW.md</code>

Control	Evidence
Paper reading-diary (pre-Lumi practice)	Physical Reading Diary Images/ (product reference)

11. Known gaps (for the reviewer)

- **School emergency-contact register.** Verified per-school emergency contacts are **not** in the repository; direct school communication (§5) and EV9 notification both depend on this register existing and being current in the contract/CRM. This is the top continuity gap.
- **Recovery targets not yet drilled.** The targets in §7 are operating expectations, not measured figures from a timed continuity exercise; a combined continuity/DR drill (§9) must be run and recorded to substantiate them.
- **Single-operator dependency.** Continuity actions currently rest on one person (the Director); the EV9 backup-lead arrangement should be confirmed for continuity too so recovery does not depend on one individual's availability.
- **Sign-off.** This plan requires the Director's sign-off before it is the governing document.



Lumi Reading · Security & Privacy Evidence

EV8

Disaster Recovery Plan

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT

ST4S item: EV8 (disaster recovery plan), also evidences D3 (data can be restored from backup; a restore has been tested) **Version:** 0.1 DRAFT · **Date:** 2026-07-24 **Status:** Draft for review — not yet signed

1. Purpose and scope

This plan defines how Lumi Reading recovers its **data** after loss or corruption — an accidental mass deletion, a bad write/migration, a rules regression that damaged data, or a platform-level data-loss event — including the recovery-point and recovery-time objectives, the backups those objectives rest on, the restore runbook, and how a restore is verified. It complements the business-continuity plan ([docs/security/evidence/EV7_BUSINESS_CONTINUITY_PLAN.md](#), which covers keeping schools operating during an outage) and the incident-response plan ([docs/security/evidence/EV9_INCIDENT_RESPONSE_PLAN.md](#), whose recovery step invokes this procedure). Where a figure is a target rather than a drilled, recorded measurement, it is called out (§6, §11).

Scope: the durable data of the [lumi-ninc-au](#) project ([australia-southeast1](#)) — the production Firestore database (the system of record for schools, classes, children, reading logs, entitlements) and Cloud Storage (book covers and transient comprehension audio) — plus the configuration and code needed to bring the service back (security rules, indexes, functions, portals), which are recovered as version-controlled artefacts rather than from a data backup.

2. Recovery objectives (RTO / RPO)

These are **policy targets**. They are consistent with the deployed backup mechanisms (§3) but the actual achievable times must be confirmed by a recorded restore drill (§6, §11).

Data class	RPO target (max data loss)	RTO target (time to restore)
Firestore — system of record	Near-zero within the 7-day PITR window (restore to a chosen past timestamp before the damage)	Same business day for a scoped restore; ≤24 h for a full-database restore
Cloud Storage — book covers	Non-critical / reconstructable (non-personal cover images)	Best-effort; not on the critical path
Cloud Storage — comprehension audio	Transient by design (written pre-sync, deleted after processing) — not a recovery target	n/a
Rules / indexes / functions / portals (config + code)	Zero (version-controlled)	Redeploy from main within the deploy window

RPO is bounded by how far back recovery can reach: Firestore PITR retains a recoverable version for **7 days**, so an incident must be caught and a recovery point chosen within that window (§11).

3. What is backed up, and its durability

- Firestore point-in-time recovery (PITR) — 7 days, ENABLED.** PITR is enabled on the production ([default](#)) database, allowing recovery of data as it existed at a chosen timestamp within the past seven days. This is the primary data-recovery control and is confirmed live in the operations audit ([docs/security/OPERATIONS_HEALTH_AUDIT_2026-07-17.md](#), [docs/security/AU_RESOURCE_LOCATION_AUDIT_2026-07-17.md](#)).
- Firestore deletion protection — ENABLED.** The database carries deletion protection, preventing accidental deletion of the database itself (confirmed in the same audits).
- Cloud Storage durability.** User-content buckets are in Sydney ([australia-southeast1](#)) on Google Cloud Storage, which provides very high vendor-stated object durability. Storage's recovery criticality is low: covers are non-personal and reconstructable, and comprehension audio is transient (deleted after processing). Object versioning / soft-delete retention on the buckets is a reviewer-confirm item (§11).
- Configuration and code as backup.** Security rules, indexes, Cloud Functions and both portals are recovered by **redeploying the version-controlled known-good revision** from [main](#) (squash-merge history gives a clean revert point; the admin portal also retains Cloud Run revisions) — see [docs/security/evidence/EV13_SECURE_SDLC.md](#) §8. There is no separate "backup" of these because the repository *is* the backup.

NOTE — PITR is not instant purge. A Firestore document deletion does not immediately purge its PITR versions; conversely, recoverable history only extends 7 days back. Record when inaccessible backup/PITR data ages out during any incident (shared note with EV9 §7).

4. Restore runbook

Recovery is performed by the Technical Lead against the reviewed known-good baseline. Steps:

1. **Contain first.** Stop the process that is causing or compounding the damage (halt the offending job/deploy, roll back a bad ruleset, disable a feature via its kill switch) so the corruption does not extend past the chosen recovery point. (Incident handling: EV9 §5.)
2. **Choose the recovery point.** Identify the last-good timestamp *before* the damage, within the 7-day PITR window. Separate "date occurred" from "date discovered".
3. **Recover the data.**
 - *Scoped corruption:* read the affected documents as-of the recovery timestamp via Firestore PITR and repair them idempotently, preferring the narrowest restore that fixes the damage.
 - *Broad/mass loss:* restore the database to a new/target database from the PITR timestamp using the Firebase/[gcloud firestore](#) recovery tooling, then reconcile against the live database before cutover.
4. **Recover configuration/code if implicated.** Redeploy the last known-good rules/indexes/functions/portal revision from [main](#) (EV13 §8); confirm the active rules **hash** matches the reviewed baseline.
5. **Recover Storage only if needed.** For a lost cover, re-upload/regenerate; audio is not recovered (transient by design).
6. **Verify before returning to service** (§5).
7. **Record** the incident, the recovery point chosen, actions and timings in the incident register (EV9 §10).

5. Verification (before service is restored)

- **Integrity/counts.** Compare restored collection counts and sampled documents against expected values (the prior drill's method — matching sampled production counts, §6).
- **Security posture intact.** Confirm deployed rules/config/code **hashes**, runtime IAM, API-key restrictions and Storage access match the reviewed known-good baseline — a restore must not reopen an access-control or tenant-isolation gap.
- **Negative tests.** Re-run the cross-tenant negative tests (Firestore Emulator matrix, [functions/test/firestore.rules.test.js](#), [functions/test/security_poc.rules.test.js](#)) and a production synthetic-denial probe against the restored state.
- **Alerts.** Confirm operational alerts still reach both security inboxes ([docs/security/OPERATIONS_HEALTH_AUDIT_2026-07-17.md](#)).

6. Restore-drill status (D3)

A **prior timed restore drill matched sampled production counts**, recorded in the operations health audit

([docs/security/OPERATIONS_HEALTH_AUDIT_2026-07-17.md](#) — "Firestore recovery: seven-day PITR and deletion protection enabled; prior timed restore drill matched sampled production counts"). This demonstrates the mechanism works.

NOTE — formal restore drill must be performed and recorded (Nic). D3 requires a **documented, repeatable, signed** restore drill: a defined scenario and recovery point, the exact restore steps executed, the measured restore time (against the §2 RTO) and data-completeness result, the verification in §5, and a dated record with the operator's sign-off. The prior drill in the ops audit is supporting evidence but is not yet captured as a formal, repeatable DR-drill record. **D3 is answered on the basis that this formal drill is completed and filed.** Until then, treat D3 as *pending the recorded drill* (§11).

7. Data residency during recovery

Recovery stays within Sydney ([australia-southeast1](#)): the Firestore database, its PITR data and the user-content Storage buckets are all Sydney-resident ([docs/security/AU_RESOURCE_LOCATION_AUDIT_2026-07-17.md](#)). Restore operations must target Sydney databases/buckets and must not export child data to another region. The documented cross-border exceptions (Firebase Authentication is US-only; the [_Required](#) audit-log bucket is global) are unchanged by recovery and are covered in the resource-location audit, not here.

8. Roles

The Technical Lead (Nic, Director; backup coordinates approved technical assistance) executes the restore; the same person records the recovery point, actions and timings. Where the disaster is also a security incident, EV9 governs and this procedure is its recovery step (EV9 §7). Destructive evidence deletion is not authorised during recovery.

9. Review

This plan is reviewed at least annually, after any real recovery event, and whenever the backup configuration changes (e.g. a change to PITR retention, deletion protection, or Storage versioning). Each formal restore drill (§6) is recorded and its result feeds the next review — including any revision to the §2 RTO/RPO targets.

10. Supporting evidence index

Control	Evidence
Firestore PITR (7-day) + deletion protection	docs/security/OPERATIONS_HEALTH_AUDIT_2026-07-17.md , docs/security/AU_RESOURCE_LOCATION_AUDIT_2026-07-17.md

Control	Evidence
Data residency (Sydney) of DB / Storage / PITR	docs/security/AU_RESOURCE_LOCATION_AUDIT_2026-07-17.md
Prior timed restore drill (counts matched)	docs/security/OPERATIONS_HEALTH_AUDIT_2026-07-17.md
Config/code recovery via redeploy + rollback	docs/security/evidence/EV13_SECURE_SDLC.md §8
Post-restore verification (rules hash, negative tests)	functions/test/firestore.rules.test.js , functions/test/security_poc.rules.test.js , docs/privacy/RELEASE_PRIVACY_SECURITY_REVIEW.md
Incident recovery context	docs/security/evidence/EV9_INCIDENT_RESPONSE_PLAN.md §7
Continuity counterpart	docs/security/evidence/EV7_BUSINESS_CONTINUITY_PLAN.md

11. Known gaps (for the reviewer)

- **Formal restore drill (D3) — top gap.** A documented, repeatable, signed restore drill measuring restore time and data completeness must be performed and filed (Nic). D3 is answered on that basis; until the recorded drill exists, D3 is *pending*, not met.
- **RTO/RPO not yet substantiated.** The §2 targets are policy figures; the recorded drill must confirm the achievable restore time and update the targets if needed.
- **Backup scope beyond PITR.** PITR gives a 7-day window; confirm whether a longer-horizon managed **scheduled backup** (with defined retention) is required and, if so, configure and record it. Also confirm Cloud Storage object versioning / soft-delete retention on the user-content buckets.
- **Restore runbook is procedural, not yet scripted/tested end-to-end.** §4 is the documented procedure; the drill (§6) is what proves it executes as written.
- **Sign-off.** This plan requires the Director's sign-off before it is the governing document.



Lumi Reading · Security & Privacy Evidence

D3

Backup Restore Drill — Record

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

COMPLETED 2026-07-24 · SIGNATURE PENDING

Completed record — drill performed 2026-07-24; pending Nic's signature · (repeat at least annually) *This is the filled D3 evidence: a live point-in-time restore was executed, completeness verified, and the temporary copy deleted. Print/save the signed copy to the evidence pack (folder [EV8](#) / [D3](#)).*

Why: D3 asks you to prove backup **restoration has been tested** — not just that backups exist. A test restore was performed, the recovered data confirmed correct, and the result recorded here.

1. Drill details

- Date performed:** 2026-07-24 (times in UTC below; AEST = UTC+10)
- Performed by:** Nicholas Plevritis (Security Lead) — executed via an authorised in-session automation run under written authorisation given 2026-07-24 ("run the PITR restore drill into a new temporary database and delete it afterwards").
- Systems in scope:** ☒ Firestore ☐ Cloud Storage ☐ Both (*Firestore only this cycle; Storage restore is a follow-up — see §4.*)
- Type:** ☒ Point-in-time recovery (PITR) ☐ Restore from export/backup

2. Method

- Source restored from:** production [\(default\)](#) database, PITR snapshot at **2026-07-24T05:20:00Z**. PITR window at drill time: earliest **2026-07-17T05:25Z** → now (7-day continuous retention), confirmed by [databases describe](#) .
- Target (NOT production):** a new, separate database [restore-drill-2026-07-24](#) in the same project ([lumi-ninc-au](#) , [australia-southeast1](#)). The restore is **create-only** — GCP requires a new destination name and never writes to the source, so production [\(default\)](#) was untouched throughout and kept serving live traffic.
- Steps taken:**
 - Confirmed PITR window + delete-protection on [\(default\)](#) via [gcloud firestore databases describe](#) (read-only).
 - Ran [gcloud firestore databases clone --source-database=../\(default\) --snapshot-time=2026-07-24T05:20:00Z --destination-database=restore-drill-2026-07-24](#) .
 - Polled the clone operation to [done](#) (100%).
 - Verified completeness with **count aggregations only** (no document contents read → no PII surfaced): every top-level collection, plus collection-group counts on key subcollections.
 - Disabled the clone's inherited delete-protection and **deleted** the temporary database.
 - Confirmed only [\(default\)](#) remains and its posture (PITR + delete-protection) is unchanged.

3. Results

Measure	Result
RTO — time from start to data available	14 min 26 s (operation 05:25:51Z → 05:40:17Z). Target: < 4 h → met with wide margin .
RPO — how recent the recovered data was	Near-zero . Snapshot chosen 5 min before drill start; PITR gives whole-minute granularity across a continuous 7-day window, so any point in the last 7 days is recoverable. Target ≤ 24 h → met .
Completeness — record counts vs source (spot-check)	☒ matched . Top-level: 36/36 collections identical. Collection-group counts identical: students 52=52 , readingLogs 608=608 , allocations 45=45 , classes 14=14 , messages 0=0 , comprehensionResponses 0=0 .
Integrity — security rules re-applied + verified (rules hash)	☒ noted. Version-controlled firestore.rules sha256 18d9968d...565d422 is the authoritative ruleset. The ephemeral clone was verification-only and never brought into service, so rules were not redeployed to it; a real recovery redeploys this exact ruleset (+ firestore.indexes.json) to the restored DB before it serves traffic (captured as a runbook step — §4).
Isolation — cross-tenant negative check on restored data	☒ covered by controls, not exercised live on the ephemeral clone. Tenant isolation is enforced by the same version-controlled firestore.rules and regression-tested by functions/test/security_poc.rules.test.js (S4 cross-tenant sweep denied); those controls travel with the restored ruleset.

Confidential · Lumi Education Pty Ltd · ABN 45 700 349 015

Page 31 of 60

4. Outcome

- **Result:** ☒ Pass ☐ Pass with issues ☐ Fail
- **Issues found / follow-ups:**
 1. **Backup schedules were absent** before this drill (PITR + delete-protection were on, but no scheduled backups existed). **Remediated same session:** created a **daily** schedule (7-day retention) and a **weekly** Sunday schedule (14-week retention) on `(default)`.
 2. **Recovery runbook must include a rules/indexes redeploy step** — a cloned/restored database starts with default rules; the DR runbook (EV8) should redeploy `firestore.rules` + `firestore.indexes.json` to the restored database before cutover, and re-verify the rules hash above.
 3. **Cloud Storage restore not yet drilled** — this cycle covered Firestore only. Add a Storage bucket restore/verify to the next drill for full coverage.
- **Next drill due: 2027-07-24** (annually), or sooner after a major infrastructure change.

5. Sign-off

Performed & verified by: Nicholas Plevritis Signature: _____ Date: 2026-07-24 (*Nic to countersign*)

Reference: the Disaster Recovery Plan (EV8) describes the full RTO/RPO targets and restore runbook this drill exercises. Posture at drill time: `(default)` FIRESTORE_NATIVE, australia-southeast1, PITR ENABLED, DELETE_PROTECTION ENABLED; backup schedules daily-7d + weekly-14w created 2026-07-24.



Lumi Reading · Security & Privacy Evidence

HR 1 / HR 2 / HR 3

HR Security Pack

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT

ST4S items: HR1 (personnel screening), HR2 (security awareness training), HR3 (offboarding / access revocation) **Related:** A7 (access review/revocation), A10 (device standard), child-safety obligations **Version:** 0.1 DRAFT · **Date:** 2026-07-24 **Status:** Draft for review — not yet signed

1. Purpose and scope

This pack defines the human-side security controls for Lumi Reading: who is screened before they can touch student data, what security awareness training everyone completes, and how access is removed when someone leaves or a role ends.

Scope: every person with any access to Lumi student data or the systems that hold it — today that is the single director; on engagement, any contractor, adviser, or support person. The three sections map one-to-one to ST4S HR1/HR2/HR3 and share one driving artefact — the **Access Register** (`ACCESS_REGISTER_TEMPLATE.md`) — which is the authoritative list of who has access to what and therefore what must be screened, trained, and revoked.

Truthfulness note. This pack states the **standard** and the records required to evidence it. It does **not** assert that a specific check, a specific training completion, or a specific revocation has occurred — those are Nic's real-world actions and become evidence only once done and dated (see §5). No check reference numbers, personal identifiers, or other PII appear in this document or in git; only the *outcome* (e.g. "current WWCC held — verified") is recorded in the evidence pack, with the underlying detail kept in a restricted HR file.

2. Section A — Employment / engagement screening standard (HR1)

2.1 Standard

Before **any** person is given access to Lumi student data (the app data, the `lumi-ninc-au` production project, the portals, or the support/admin mailboxes), they must hold:

- a **current Working With Children Check (WWCC)** valid for the relevant jurisdiction (Lumi operates with Australian schools; the WWCC is the primary, mandatory screening for anyone who can access children's data); and
- optionally, a National Police Check (NPC)** where warranted by the role or requested by a partner school as an additional assurance.

The check must be **verified as current** — sighted and confirmed against the issuing authority, not merely asserted — before access is granted, and re-verified on expiry.

2.2 What is recorded, and where

Field	Stored where
Check type (WWCC / NPC)	Restricted HR file (not git)
Reference / card number	Restricted HR file only — never git, never this pack
Issue date, expiry date	Restricted HR file (expiry drives re-verification)
Outcome ("current — verified", verifier, date verified)	Evidence pack (this is the only field surfaced for ST4S)

The evidence pack contains only the outcome line. The underlying document, card number, and personal details are held in a restricted HR file (e.g. password manager / encrypted store), consistent with data-minimisation and with §5 of the device standard (no PII in the repo).

2.3 Cadence

- Before access:** no student-data access is granted until a current WWCC is verified (this is a hard gate in onboarding, §4).
- On expiry:** the expiry date in the restricted HR file drives re-verification; a lapsed check means access is suspended until renewed.
- Annual reconciliation:** at the annual access review, confirm every person in the Access Register still holds a current check.

3. Section B — Security awareness training program (HR2)

3.1 Standard

Everyone with access completes **security awareness training at least annually** (and at onboarding, before or immediately on being granted access). Training covers the ST4S content areas:

1. **Phishing & social engineering** — recognising and reporting suspicious email/SMS/calls; that Lumi will never ask for a password/OTP; verifying unexpected requests out of band.
2. **Passwords & MFA** — the Lumi credential standard (14+ / complexity, per A2), a password manager, unique passwords per system, and mandatory MFA on privileged accounts (per [ACCESS_CONTROL_POLICY.md](#) §6).
3. **Data handling & classification** — what counts as student PII, minimisation, Australian data-residency ([lumi-ninc-au](#), [australia-southeast1](#)), and not moving student data out of approved systems.
4. **Incident reporting** — how and when to raise a suspected incident, and the response path ([EV9_INCIDENT_RESPONSE_PLAN.md](#)); report early, don't sit on it.
5. **Device security** — the endpoint standard ([DEVICE_STANDARD.md](#)): lock screen, encryption, updates, no shared accounts, lost-device response.
6. **Privacy & child-safety obligations** — child-safety duty of care, WWCC obligations, the privacy policy and APP obligations, and appropriate handling of children's information.
7. **Acceptable use** — approved-systems-only, no credentials in code/tickets, no shadow tools handling student data, and the branch→PR→review workflow as a security control (peer review before merge).

3.2 Delivery and records

- Training may be delivered via a reputable external module (e.g. a security awareness provider) and/or an internal walkthrough of the ST4S content areas above and these policies.
- **Completion is recorded and dated:** name, date completed, module/version, and topics covered. The dated completion record is the HR2 evidence.
- New joiners complete it at onboarding (§4); everyone re-completes annually.

3.3 Records template

Person (named)	Role	Module / content version	Date completed	Next due	Evidence (certificate / attestation ref)
Nic (Director)	Director / all access	ST4S content areas 1–7 + policy walkthrough	2026-...-...	+12 months	(certificate / signed attestation)

4. Section C — Offboarding / access-revocation checklist (HR3)

4.1 Standard

When a person leaves, a role ends, or a device/engagement is terminated, **all system access is revoked same-day** — and **immediately** where the departure is involuntary or there is any suspicion of malicious intent. Revocation is driven by that person's row(s) in the **Access Register** so nothing is missed.

4.2 Trigger and timing

Situation	Timing
Planned departure / engagement end	Same business day as the last day
Involuntary / for-cause / suspected malicious	Immediately — before or at notification; treat as a potential incident (EV9_INCIDENT_RESPONSE_PLAN.md)
Role change (reduced scope)	Same-day downgrade to least privilege for the new role

4.3 Checklist (run against the leaver's Access Register rows)

For each system the person appears against in the Access Register, revoke and record the date/time:

- ☐ **Identity / SSO** — disable the Google/Workspace or primary identity; end active sessions.
- ☐ **GCP / Firebase** ([lumi-ninc-au](#)) — remove all IAM role bindings; confirm no lingering service-account impersonation or key access.
- ☐ **GitHub** — remove from the org/repo; revoke personal access tokens, SSH keys, and any OIDC/CI trust tied to the person.
- ☐ **Apple Developer** — remove from the team; revoke signing access.
- ☐ **Google Play Console** — remove user and permissions.
- ☐ **Portals** — remove/disable super-admin ([/superAdmins/{uid}](#)) and any school-admin/teacher membership; per [ACCESS_CONTROL_POLICY.md](#) §3.3 and the server-op offboarding path, this revokes app-level access too.
- ☐ **Support / admin mailboxes** — remove delegated access to support/admin/demo/review mailboxes; reset shared-mailbox credentials if the person knew them.
- ☐ **Domain registrar & DNS** — remove account access; rotate credentials if shared.
- ☐ **Cloudflare** (status worker / edge) — remove account access; rotate API tokens the person held.
- ☐ **Password manager** — revoke vault access; **rotate every shared secret** the person could have seen (this is the critical step for a for-cause exit).
- ☐ **Devices** — collect or remotely wipe any Lumi device ([DEVICE_STANDARD.md](#) §5); retire the device-register row.
- ☐ **Access Register** — mark every row revoked with date/time and who performed it; the register is the completed evidence.

4.4 Verification

After revocation, confirm the person can no longer authenticate to any system (spot-check the highest-risk: GCP/Firebase, GitHub, super-admin portal), and that every shared secret they could have known has been rotated. Record the verification date. A for-cause exit additionally runs the incident-response review to check for any action taken before revocation.

5. Supporting evidence index

Control	Evidence (owned by Nic)
Screening standard (HR1)	Restricted HR file (type/ref/date/expiry) + outcome line in the evidence pack ("current WWCC verified", verifier, date)
Awareness training (HR2)	Dated completion record / certificate per person (§3.3)
Offboarding (HR3)	Completed checklist (§4.3) with dated revocations, driven by the Access Register
Access register (driver for HR1 & HR3)	ACCESS_REGISTER_TEMPLATE.md (populated)
Server-side portal/app revocation	ACCESS_CONTROL_POLICY.md §3.3, §8 (super-admin + membership offboarding)
Device collection / wipe	DEVICE_STANDARD.md §5
Incident path for for-cause exits	EV9_INCIDENT_RESPONSE_PLAN.md

6. Known gaps / reviewer must confirm

- **NIC — WWCC HELD (2026-07-24); just record the details.** Nic holds a current WWCC, so HR1 screening for the director is met in substance. Remaining step: record its type/reference/date/expiry in the **restricted HR file (not git)** and add a one-line *outcome* to the evidence pack ("current WWCC held — verified [date]"). Repeat for any contractor/adviser who later gains access to student data.
- **NIC — training not yet completed.** §3 defines the program; the **dated completion record** for each person (starting with the director) must exist for HR2 to be evidenced.
- **NIC — offboarding is untested until used.** The §4 checklist is real and driven by the Access Register, but there is no completed run yet (single operator). Confirm it is exercised on the first real departure, and consider a dry-run against the register to prove no system is missed.
- **Access register dependency.** HR1 and HR3 both depend on a **populated** Access Register ([ACCESS_REGISTER_TEMPLATE.md](#)); that register is currently a template awaiting Nic's population and first review.
- **Restricted HR file location.** Confirm where the restricted HR file lives (password manager / encrypted store) and that it holds no PII in git.
- **Sign-off.** This pack requires Nic's sign-off, and HR1/HR2/HR3 are only ST4S-submittable once the real check, the dated training record, and the populated register exist.



Lumi Reading · Security & Privacy Evidence

HR 2

Security Awareness Training — Record

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

COMPLETED 2026-07-24 · SIGNATURE PENDING

Completed record — filled 2026-07-24; pending Nic's signature · (recurs annually) *This records the annual security awareness training completed by Nic on 2026-07-24 (per Nic's confirmation). Print/save the signed copy to the evidence pack (folder **HR**).*

Why: HR2 asks for a security awareness training **program** plus **dated records** that people actually completed it. A self-run annual session is acceptable for a sole founder.

1. Program — content areas (cover all of these)

- ✓ **Phishing & social engineering** — spotting suspicious emails/links, reporting them.
- ✓ **Passwords & MFA** — strong unique passwords (14+/complexity), password manager, MFA/passkeys on every privileged account.
- ✓ **Data handling & classification** — what counts as student/child personal information; never put child names, notes, recordings, tokens, or emails into logs, analytics, screenshots, or public APIs.
- ✓ **Incident reporting** — how to recognise and report a suspected incident (per the Incident Response Plan, EV9).
- ✓ **Device security** — screen lock, FileVault, updates, no shared accounts (per the Device Standard).
- ✓ **Privacy & child-safety obligations** — APPs, the Notifiable Data Breaches scheme, child-safety duties.
- ✓ **Acceptable use** — of company systems, accounts, and data.

Suggested materials: OAIC privacy basics, the Australian Cyber Security Centre (ACSC) small-business guidance, and Lumi's own Information Security Policy (EV6) + Incident Response Plan (EV9).

2. Completion record

Date completed	Participant	Role	Topics covered	Materials used	Notes
2026-07-24	Nicholas Plevritis	Founder / Security Lead	All of §1 (phishing, passwords/MFA, data handling, incident reporting, device security, privacy/child-safety, acceptable use)	Self-directed independent session (<i>Nic: note specific materials used</i>)	Completed 2026-07-24; Nic to countersign

3. Cadence

- Annual**, and on onboarding of any new person with access to student data.
- Next due: **2027-07-24**.

Signed: Nicholas Plevritis Date: 2026-07-24 Signature: _____ (*Nic to sign*)



Lumi Reading · Security & Privacy Evidence

A7

Access Register (Privileged / Operator)

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

FIRST REVIEW 2026-07-24 · SIGNATURE PENDING

ST4S item: A7 (access review / revocation) **Related:** A6/A13 (access control — [ACCESS_CONTROL_POLICY.md](#)), HR1/HR3 ([HR_SECURITY_PACK.md](#)), A10 ([DEVICE_STANDARD.md](#)) **Version:** 1.0 · **Date:** 2026-07-24 **Status:** Populated · first review performed 2026-07-24 · MFA confirmation + signature pending

1. Purpose and scope
- The access register is the single authoritative list of **who has access to which system, at what level, and when that access was last reviewed**. It is the driving artefact for A7 (periodic access review) and for HR offboarding ([HR_SECURITY_PACK.md](#) §4 — a leaver's rows are exactly what must be revoked). [ACCESS_CONTROL_POLICY.md](#) §9 names this register as a required standing document.
- Scope: every **human** principal (today: the director; on engagement: any contractor or adviser) against every system that can reach Lumi code, the production project, or student data. Application end-users (parents, teachers, school admins) are **not** in this register — their access is governed server-side by the security rules and membership documents ([ACCESS_CONTROL_POLICY.md](#) §2–3) and reviewed through the membership/rollover cadence, not here. This register is the **privileged / operator** access list.
- Data-minimisation note.** No passwords, tokens, keys, MFA seeds, or personal identifiers appear here — the register records *that* access exists and its level, never the credential itself. Those live in the password manager / secret store.

2. Current principals

#	Person (named)	Role	Screening (HR1)	Device (A10)
1	Nicholas Plevritis	Founder / Director — Security Lead (GO1) & Privacy Officer (GO2); sole operator	Current WWCC held — verified 2026-07-24 (detail in restricted HR file)	Primary workstation on the device register (DEVICE_STANDARD.md §4)

Single-principal estate. Any contractor/adviser who later gains access is added as a new principal here **after** HR1 screening + HR2 training + device standard are met, at least privilege for their role.

3. Register — matrix form (one row per person; cell = access level, "—" = none)

Person	GCP/Firebase lumi-ninc-au	GitHub	Apple Dev	Google Play	School portal	Super-admin portal	Mailboxes	Domain registrar	Cloudflare	Password mgr	MFA on all?	Last reviewed
Nicholas Plevritis	Owner	Org-Owner	Account-Holder	Account-Owner	super-admin	super-admin (MFA-enforced)	Owner	Account-Owner	Account-Owner	Owner	 confirm (see §5)	2026-07-24

4. Register — per-system detail (authoritative long form)

One row per (person × system) with justification, MFA, and the review action.

Person	System	Access level	Business justification (least-privilege test)	MFA enforced?	Date granted	Last reviewed	Reviewer	Action
Nic	GCP / Firebase lumi-ninc-au	Owner	Sole operator of the production project; no other principal to delegate to	 confirm	Project inception	2026-07-24	N. Plevritis	keep
Nic	GitHub (repo/org)	Org-Owner	Sole maintainer; owns CI/CD + deploy trust	 confirm	Repo inception	2026-07-24	N. Plevritis	keep

Person	System	Access level	Business justification (least-privilege test)	MFA enforced?	Date granted	Last reviewed	Reviewer	Action
Nic	Apple Developer / App Store Connect	Account-Holder	Sole publisher of the iOS app	🔒 confirm	Enrolment	2026-07-24	N. Plevritis	keep
Nic	Google Play Console	Account-Owner	Sole publisher of the Android app	🔒 confirm	Enrolment	2026-07-24	N. Plevritis	keep
Nic	School admin portal (school-admin-web)	super-admin	Operational support for schools	inherits portal MFA	Portal launch	2026-07-24	N. Plevritis	keep
Nic	Super-admin portal (admin/)	super-admin (/superAdmins/{uid})	Cross-tenant Lumi operations	enforced (admin TOTP, ACCESS_CONTROL_POLICY.md §6)	Portal launch	2026-07-24	N. Plevritis	keep
Nic	Support / admin mailboxes	Owner	Owns support@ + demo/review mailboxes	🔒 confirm	Setup	2026-07-24	N. Plevritis	keep
Nic	Domain registrar	Account-Owner	Owns the domain + DNS of record	🔒 confirm	Domain purchase	2026-07-24	N. Plevritis	keep
Nic	Cloudflare (edge / status worker)	Account-Owner	Owns the status-banner worker + any edge/DNS	🔒 confirm	Worker setup	2026-07-24	N. Plevritis	keep
Nic	Password manager	Owner	Custody of all secrets + recovery keys	🔒 confirm	Setup	2026-07-24	N. Plevritis	keep

Vendors without a human console login (server-to-server sub-processors) are tracked in SUB_PROCESSOR_TABLE.md , not here. Any vendor console a human logs into (e.g. billing entity portal, error/analytics tooling) is added as a row above when adopted.

5. First review — findings (2026-07-24)

Reviewer: Nicholas Plevritis · Date: 2026-07-24 · Scope: all rows in §4.

1. **All access is appropriate and at the minimum feasible level for a single-operator estate.** With one principal, every system's least-privilege baseline is owner/holder — there is no second principal to reduce against, so every row's action is **keep**. No excess or stale grants found; no unknown principals.
2. **One open action — MFA confirmation (🔒).** MFA is **confirmed enforced** on the super-admin portal (admin TOTP). For the remaining consoles marked "🔒 confirm" (GCP/Firebase Google account, GitHub, Apple, Google Play, mailboxes, domain registrar, Cloudflare, password manager) Nic must **log in and confirm 2FA is on**, then change each "🔒 confirm" to "enforced" and countersign. This is the only item preventing this register from being complete A7 evidence.
3. **Improvement (not a finding).** Best practice even for a sole operator is to use a least-privilege day-to-day identity and reserve Owner for break-glass; adopt this at the point a second principal joins (tracked in ACCESS_CONTROL_POLICY.md).

6. Review cadence (A7)

Trigger	Action	Frequency
Annual review	Walk every row: confirm the person still needs the access at that level; reduce to least privilege or revoke; confirm MFA; stamp "date last reviewed" and reviewer	Annual (next due 2027-07-24)
On role change	Grant/reduce access for the new role same-day; add/adjust rows	On change
On joiner	Add rows only after HR1 screening + HR2 training + device standard met; default least privilege	On event
On leaver / for-cause	Revoke every row same-day (immediately if malicious) per HR_SECURITY_PACK.md §4; the register is the checklist	On event
Monthly IAM spot-check	The GCP/Firebase IAM + deploy-identity subset is reviewed monthly (ACCESS_CONTROL_POLICY.md §8); reconcile findings back into this register	Monthly (IAM subset)

The **annual full-register review** is the A7 evidence: a dated pass (this §5 being the first) where every row's "last reviewed" is stamped and each access is confirmed keep/reduce/revoke by a named reviewer.

7. Relationship to other controls

- **Access control policy.** The server-side application access model and the monthly IAM / privileged-session cadence live in `ACCESS_CONTROL_POLICY.md` §8; this register is the *human/operator* companion it §9 requires.
- **HR pack.** Screening (HR1) and offboarding (HR3) are driven from this register (`HR_SECURITY_PACK.md`).
- **Device standard.** Adding a person usually adds a device; keep the device register (`DEVICE_STANDARD.md` §4) in step with joiner/leaver events here.

8. Sign-off

First review performed and register populated by: **Nicholas Plevritis** Signature: _____ Date: 2026-07-24

Open before final sign-off: complete the MFA confirmations in §5 item 2 (change each "🔒 confirm" to "enforced"). Once done, this register is complete A7 evidence.



Device Security Standard

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT

ST4S item: A10 (endpoint / device security) **Related:** S7 (server/endpoint protection), EV12 §9 (endpoint OS patching) **Version:** 0.1 DRAFT · **Date:** 2026-07-24 **Status:** Draft for review — not yet signed

1. Purpose and scope

This standard defines the minimum security configuration for **every device used to do Lumi Reading work** — that is, any device from which someone can access Lumi source code, the production project (`lumi-ninc-au`, `australia-southeast1`), the admin/support mailboxes, the Firebase/GCP console, the portals, or student data. It exists so that a lost, stolen or compromised endpoint cannot become a path to child data or to the production estate.

Scope today is small and named: Lumi is operated by a single director, so the in-scope estate is the macOS build/development machine plus any iPhone/iPad used for on-device testing, store submission, or accessing Lumi accounts. Any future contractor or adviser device that touches the above is in scope from day one and must meet this standard **before** access is granted (see the Access Register, `ACCESS_REGISTER_TEMPLATE.md`, and HR onboarding, `HR_SECURITY_PACK.md` §3).

Truthfulness note. This document states the **required** posture and the evidence needed to prove it. It does **not** by itself assert that every setting below is currently applied — the settings marked "confirm" in §8 must be verified against the actual devices and evidenced (screenshots + the device register) before this standard can be treated as *in force*. Where a control is already known to be the platform default (e.g. macOS Gatekeeper/XProtect ship enabled), that is noted, but per-device confirmation is still required.

2. Principles

- **Every Lumi device is hardened, encrypted and up to date.** There is no "personal, therefore out of scope" device — the test is whether it can reach Lumi data or accounts, not who owns it.
- **The device is not a trusted perimeter.** Endpoint hardening is defence in depth *behind* the server-side controls (deny-by-default rules, server-defined authorization, MFA on privileged accounts). It reduces the blast radius of a compromised endpoint; it is not a substitute for the access controls in `ACCESS_CONTROL_POLICY.md`.
- **No shared identities.** Each person uses their own OS user account and their own credentials to each system; devices and logins are attributable to one named human.
- **Evidenced, not assumed.** Each control has a defined way to prove it is on (a screenshot, a command output, or a register entry), captured at onboarding and re-confirmed at the annual review.

3. Required device configuration

The following is the required baseline for every in-scope macOS device. Each row names how it is verified for the evidence pack.

#	Control	Requirement	How to verify (evidence)
3.1	Screen auto-lock	Display turns off / screensaver starts after ≤ 15 minutes of inactivity	System Settings → Lock Screen → "Start Screen Saver when inactive" / "Turn display off"; screenshot
3.2	Password on wake	Password required immediately (0 seconds) after sleep or screensaver begins	System Settings → Lock Screen → "Require password after..." = "immediately"; screenshot
3.3	Full-disk encryption	FileVault ON for the whole startup disk; recovery key stored safely (see §5)	System Settings → Privacy & Security → FileVault = On; or <code>fdsetup status</code> → "FileVault is On"; screenshot
3.4	Application firewall	macOS application firewall enabled (stealth mode on where practical)	System Settings → Network → Firewall = On; or <code>socketfilterfw --getglobalstate</code> ; screenshot
3.5	Gatekeeper	Gatekeeper enabled — only App Store / identified-developer apps run	<code>spctl --status</code> → "assessments enabled"; screenshot
3.6	XProtect / malware protection	Apple's built-in XProtect malware protection present and updating (ships enabled on macOS)	XProtect is a platform default; confirm automatic security-data updates are on (3.7)
3.7	Automatic OS updates	Automatic macOS updates + automatic security responses enabled; the OS is on a currently-supported major version receiving security updates	System Settings → General → Software Update → Automatic updates all on; screenshot; note current macOS version

#	Control	Requirement	How to verify (evidence)
3.8	Automatic app updates	App Store apps update automatically; developer toolchains (Xcode, CLI tools, Homebrew, Flutter/Dart, Node) kept current — security releases applied without undue delay (see EV12)	App Store → Automatic Updates on; screenshot. Toolchain currency tracked via the patch process (EV12_PATCH_MANAGEMENT.md)
3.9	No shared accounts (device)	Each person has their own OS login; no shared/guest OS account is used for Lumi work; guest account off	System Settings → Users & Groups (no shared/guest login in use); screenshot
3.10	Strong login credential	Device login password meets the Lumi credential standard (see A2), or is a passkey/biometric backed by a strong password; auto-login off	System Settings → Users & Groups → Automatic login = Off; screenshot
3.11	Find My / remote wipe	Device locatable and remote-wipeable if lost or stolen (Find My Mac / Find My iPhone)	System Settings → Apple ID → Find My = On; screenshot

Mobile (iPhone / iPad) devices used for Lumi work

Any iOS device used to access Lumi accounts, submit builds, or test on-device must additionally have: a device passcode (6+ digits / alphanumeric), Face ID / Touch ID, auto-lock ≤ 15 minutes, **data protection** (on by default when a passcode is set — hardware full-disk encryption), automatic iOS updates, and Find My iPhone enabled for remote wipe. No shared/kiosk device is used to access adult Lumi accounts. (In-app kiosk mode on classroom iPads is a separate, product-level control and is out of scope here — those are school devices, not Lumi-operator devices.)

4. Device register

A **device register** is maintained listing every in-scope device. It is the authoritative list of what must meet §3 and is reviewed at the same cadence as the access register (§7). The register itself is kept in the restricted evidence store, not in git if it contains serial numbers; only the summary/outcome is placed in the evidence pack.

Template:

Device ID / name	Type & model	OS version	Owner (named)	Encryption (FileVault/DP)	Auto-lock ≤15m + pw-on-wake	Firewall / Gatekeeper	Auto-updates	Remote wipe	Last verified	Notes
e.g. "Lumi-MBP-01"	MacBook Pro (Apple Silicon)	macOS 15.x	Nic (Director)	On	Yes / immediate	On / on	On	Find My on	2026-07-...	Primary build machine
e.g. "Lumi-iPhone-01"	iPhone	iOS 18.x	Nic (Director)	On (passcode)	Yes / immediate	n/a	On	Find My on	2026-07-...	On-device testing + store

Every row must have a corresponding evidence artefact (screenshots per §3) filed in the restricted evidence store and cross-referenced here.

5. Recovery keys and secrets

- The **FileVault recovery key** (and any iOS recovery contacts / keys) is stored in the operator's password manager or a sealed offline location — **never** in git, in the repo, in a mailbox, or in this document. This standard prints no key, serial number, or personal identifier.
- Loss of the primary device follows the incident/BCP path (EV9_INCIDENT_RESPONSE_PLAN.md): remote-wipe via Find My, then rotate any credential that was resident on the device (see the offboarding / credential-rotation steps in HR_SECURITY_PACK.md §3 and the Access Register).

6. Relationship to other controls

- Patching (EV12).** Endpoint OS and toolchain patching is governed by EV12_PATCH_MANAGEMENT.md §9; this standard supplies the *configuration* requirement (auto-updates on, supported OS version) that EV12 relies on.
- Access control (A6/A7/A13).** A hardened device is a precondition for privileged access; adding a device or a person to the estate is an access-register event (ACCESS_REGISTER_TEMPLATE.md).
- No secrets on the endpoint that matter if it's lost.** Per the release gate, no Admin credential, service-account key or unrestricted billable key lives in a client, build artifact or on the endpoint in plaintext; CI deploys keylessly via Workload Identity Federation (see ACCESS_CONTROL_POLICY.md §7). This limits what a stolen-but-encrypted device could expose.

7. Review cadence

Trigger	Action	Frequency
New device or new person	Verify §3 in full, capture evidence, add to the register before granting Lumi access	On change
Annual review	Re-confirm every register row still meets §3; refresh screenshots; retire decommissioned devices	Annual
Device lost / stolen / decommissioned	Remote-wipe, rotate resident credentials, mark the row retired with date	On event
Major OS end-of-support	Upgrade to a supported major version before it stops receiving security updates	As released

8. Supporting evidence index

Control	Evidence (to be filed by Nic)
Auto-lock ≤15m + password-immediately (3.1–3.2)	Lock Screen settings screenshot
FileVault full-disk encryption (3.3)	<code>fdesetup status</code> output / FileVault screenshot
Application firewall (3.4)	Firewall settings screenshot / <code>socketfilterfw --getglobalstate</code>
Gatekeeper (3.5)	<code>spctl --status</code> output
Automatic OS + security updates (3.7)	Software Update settings screenshot + current OS version
Automatic app updates (3.8)	App Store auto-update screenshot
No shared / no auto-login (3.9–3.10)	Users & Groups + login options screenshot
Remote wipe (3.11)	Find My enabled screenshot
Device register	Completed register (§4), restricted store
Related patch posture	<code>EV12_PATCH_MANAGEMENT.md</code> §9
Related access precondition	<code>ACCESS_CONTROL_POLICY.md</code> , <code>ACCESS_REGISTER_TEMPLATE.md</code>

9. Known gaps / reviewer must confirm

- **NIC — settings not yet verified.** Every control in §3 is a *requirement*, not an evidenced fact. Nic must confirm each setting is actually applied on each in-scope device and capture the screenshots/command output listed in §8. Until then this standard is not "in force" — do not submit it to ST4S as evidence of a configured endpoint.
- **NIC — device register not yet populated.** §4 is a template. Nic must complete it with the real in-scope devices (Mac(s) + any iPhone/iPad used for Lumi) and file it in the restricted evidence store.
- **NIC — screenshots for the evidence pack.** A10 evidence is the per-control screenshots/outputs; these must be captured and filed (the A2 password-policy screenshot workflow — `~/lumi-security-evidence/...` — is the model to reuse).
- **Recovery-key custody.** Confirm the FileVault recovery key is stored in the password manager / offline (per §5) and is retrievable but not exposed.
- **Toolchain-update discipline.** §3.8 asserts developer toolchains are "kept current"; confirm this is actually happening on the cadence EV12 defines, not just OS auto-updates.
- **Sign-off.** This standard requires Nic's sign-off before it is the governing document, and is only ST4S-submittable once §3 is verified and the register + screenshots exist.



Lumi Reading · Security & Privacy Evidence

PR2

Privacy Policy (rewrite)

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT — FOR ADVISER REVIEW

! PRIVACY/LEGAL-SENSITIVE DRAFT — PRIVACY ADVISER SIGN-OFF REQUIRED BEFORE PUBLISHING

This is a **draft rewrite** of Lumi's public Privacy Policy. It must **not** be published, and the live legal page ([school-admin-web/src/app/legal/privacy/page.tsx](#)) must **not** be modified, until the appointed Australian privacy adviser has reviewed and signed it off and Nic has approved it. **Do not bump the consent/version constants** on the back of this draft (that is a separate, single re-acceptance step — remediation plan Phase 6.5). This document is not legal advice.

ST4S item: PR2 (privacy policy covers all required content) **Version:** 0.1 — DRAFT for review, not yet signed **Date:** 2026-07-24 **Grounded in:** [docs/privacy/PRIVACY_IMPACT_ASSESSMENT.md](#) , [docs/privacy/VENDOR_DATA_FLOW_REGISTER.md](#) , [docs/privacy/APP_8_CROSS_BORDER_DISCLOSURE_LAWYER_BRIEF.md](#) , and the current live policy **Replaces (on approval):** the live policy last updated 15 July 2026

How to read this draft

The seven required content areas are set out **explicitly and in order** as sections (1)–(7) below, matching the PR2 checklist. Text in *[adviser: ...]* is a drafting note, not policy text, and must be resolved or removed before publication. This draft keeps every factual claim consistent with the current verified data practices; it does not assert any control that is not live (e.g. it does not claim App Check is enforced or that the AI feature is on).

Lumi Privacy Policy (draft body)

Lumi ("Lumi", "we", "us", "our") provides the Lumi Reading Diary app and related services (the "Service") to schools. Lumi handles most information about students **on behalf of, and at the direction of, the school** that enrolls them. We are committed to handling personal information consistently with the **Privacy Act 1988 (Cth)** and the **Australian Privacy Principles (APPs)**.

[adviser: insert the Lumi contracting legal entity name and ABN once confirmed; the APP-entity determination is open — see APP 8 brief §4.]

(1) The kinds of personal information we collect

Account information (teacher, school administrator, or parent/carer):

- name and the role held (parent/carer, teacher, or school administrator);
- a mobile phone number (required for parent/carer accounts, used for sign-in and reminders) and, optionally, an email address;
- for parents/carers, the relationship to the child (e.g. Mum, Dad, Guardian);
- the school and class you are associated with, and the link or school code used to join;
- an optional profile photo and chosen in-app character.

Passwords are managed by our authentication provider (Google Firebase Authentication); we do not see or store your raw password.

Student information (entered by the school and the parents/carers and teachers it authorises):

- the student's name, class and year level, and optionally date of birth and profile photo;
- reading level and the history of reading-level changes;
- reading activity — dates, minutes read, books read, how the child felt about the session, and any notes;
- optional short comprehension voice recordings (only where a school administrator has turned the feature on, confirmed the school will notify families, and chosen a 30, 90 or 365-day deletion period);
- optional photos attached to a reading log;
- messages exchanged between a teacher and a parent/carer about a reading log.

Device and technical information:

- a push-notification token, to deliver reminders and updates;
- app version and device type where needed to operate the Service;
- optional crash reports and limited product-usage analytics, **only** where an adult account holder has enabled that control on that device;
- information you provide when you contact support or send feedback.

We do **not** collect information for advertising, and we do **not** track you across other companies' apps or websites.

(2) How we collect and hold personal information

How we collect it. We collect information directly from the adults who use the Service — when a school provisions staff, when a teacher or parent/carer creates an account and enters reading activity, and when you contact support. A school (and the teachers and parents/carers it authorises) enters student information. We also receive a small amount of technical information from your device (for example, a push-notification token), and — only if you opt in — diagnostic information.

How we hold it. Information is stored using Google Cloud / Firebase infrastructure, with our **primary database and file storage hosted in Australia** (the Sydney [\(australia-southeast1\)](#) region). Information is encrypted in transit and at rest. Access is restricted by authentication and security rules so users can reach only the data they are entitled to: access is role-, class- and family-scoped, and roles are defined by the server, not asserted by the client. The database has point-in-time recovery and deletion protection. Some supporting provider systems operate overseas — see sections (6) and (7).

(3) The purposes for which we collect, hold, use and disclose it

We use personal information to:

- provide the Service — record and display reading activity, progress and achievements;
- enable communication between teachers and parents/carers about a child's reading;
- send reading reminders, achievement and comment notifications, and school announcements;
- operate and secure the Service, and — where an adult has opted in — troubleshoot and improve the app using pseudonymous crash reports or product-usage analytics;
- verify school enrolment and manage access entitlements; and
- respond to support requests and meet legal obligations.

We **disclose** personal information only as needed to run the Service:

- **Within the school community:** a child's reading information is visible to that child's teachers and school administrators, and to the parents/carers linked to the child.
- **Service providers (processors):** we use Google Firebase / Google Cloud (authentication, database, file storage, messaging and, where you opt in, crash reporting and analytics) and an email provider to send transactional email. These providers process data **on our behalf**, on our instructions, under their own security and privacy commitments. A description of our sub-processors is available on request *[adviser: link the approved sub-processor table once published — see PR17 draft]*.
- **Book look-ups:** to fetch book titles and cover images we send **only** a book's ISBN or title to public book databases (such as Google Books and the Open Library). **No student information is sent in these look-ups.**
- **Legal reasons:** where required by law, or to protect the rights, safety and security of users, the public or Lumi.

We do **not** sell personal information and do **not** use it for third-party advertising.

Children's information. Lumi is designed to be used *about* children by the adults responsible for them — schools, teachers and parents/carers — not by young children independently. The school is responsible for ensuring it has the appropriate authority and parental consent to enter student information and to enable optional features such as voice recordings.

(4) How you can access and correct your personal information

You may request access to, or correction of, the personal information we hold about you. Parents/carers can view and update much of their own and their child's information in the app, and schools can manage student records directly. A parent/carer or teacher can permanently delete their own Lumi account from **Settings → Account**. Because Lumi holds student information on behalf of schools, a parent/carer who wants a child's **school record** accessed, corrected or deleted should contact the school, or email support@lumi-reading.com. We verify a requester's authority through their existing account or the school contact before acting; legal or school record-keeping requirements may apply.

(5) How to complain, and how we handle complaints

If you have a question about this policy, or wish to make a privacy complaint, contact us at support@lumi-reading.com. We will **acknowledge** your complaint and **respond within a reasonable period**. When handling a complaint we record the requester's identity, authority, the scope of the request, our decision and completion, and we verify authority before making any change. If you are not satisfied with our response, you may contact the **Office of the Australian Information Commissioner (OAIC)** at oaic.gov.au.

[adviser: confirm the target acknowledgement/response timeframes to state here; PIA APP 12/13 requires the response workflow to record identity, authority, scope, decision and completion — reflected above.]

(6) Whether we disclose personal information overseas

Yes — some information is handled overseas. Our primary database, file storage and application processing are in **Australia** (Sydney), but some supporting provider systems operate outside Australia:

- **Account authentication** (Google Firebase Authentication) is processed in the **United States**.
- **Push notifications** are delivered through Apple and Google's **global** messaging services.
- **Transactional email** is sent through our email provider, whose infrastructure is in **North America and the European Union** (and which may process in the United States).
- **Optional** crash reporting and product-usage analytics (only if you opt in) **may be processed outside Australia**.

Where information is handled overseas, we take reasonable steps to ensure it is handled consistently with the APPs, minimise what is sent, and keep child names and content out of the flows that leave Australia wherever possible.

[adviser: this section states an overseas disclosure occurs. The APP 8 reasonable-steps analysis, and whether each flow is a disclosure or a use under Lumi's effective control, is pending your review (APP 8 brief). Confirm the wording of "reasonable steps" and whether any APP 8.2 exception is relied on — the brief advises against relying on a consent-waiver exception for a children's service.]

(7) The countries in which recipients are likely to be located

- **Australia** — primary: the Sydney (australia-southeast1) region hosts the main database, user-content storage, application compute and (going forward) ordinary logs.
- **United States** — Firebase Authentication (account identity); the email provider (Twilio, Inc.) may process there; some global platform services and Google's required audit logs.
- **North America and the European Union** — email-provider (SendGrid) infrastructure sub-processors.
- **Global / other** — Apple and Google push-notification delivery, and (only if you opt in) Analytics/Crashlytics, may be processed in other countries where those providers or their sub-processors operate.

We keep a current sub-processor list identifying each provider and the countries where it processes information; it is available on request [adviser: link the approved PR17 sub-processor table].

How long we keep information; push notifications and optional analytics

(Carried across from the current policy for completeness; unchanged in substance, subject to the same adviser review.)

- We keep information while the account/school relationship is active and as needed to provide the Service; access to a student's data is tied to the school's enrolment and annual renewal.
- **Comprehension voice recordings** are kept only for the school's chosen deletion period (30, 90 or 365 days); legacy 7-day settings are still honoured for deletion but cannot authorise new recordings; unconfirmed uploads are removed after 24 hours.
- On account deletion, core school reading events may be retained only in de-identified form so deleting an adult's login does not erase a child's educational record; a minimal completion receipt is kept for 90 days.
- You can turn off push notifications in device settings. Analytics and crash reporting are **off by default** and controlled per device in **Settings → Account → Privacy & diagnostics**. Lumi does not attach a Firebase UID, child identity, school, title, recording, note or detailed reading result to Analytics.

(An AI-assisted comprehension feature is **not** enabled in production. If it is ever turned on for a school, a separate collection notice will be issued first — see docs/privacy/AI_EVAL_COLLECTION_NOTICE_DRAFT.md). Do not reference it as a current feature.)

Evidence index

Policy claim	Evidence
Categories of information collected	PIA §2; live policy §1
AU primary hosting (australia-southeast1), encryption, scoped access	PIA §4; AU_RESOURCE_LOCATION_AUDIT_2026-07-17.md ; ACCESS_CONTROL_POLICY.md
Firebase Auth = US	Firebase DP&S Terms; PIA §3.1; APP 8 brief §5
Push = Apple/Google global	Vendor register (FCM/APNs row); APP 8 brief §5
Email provider = NA/EU/US	vendor-evidence/2026-07-17/README.md ; register (SendGrid row)
Analytics/Crashlytics opt-in, off by default, no Lumi UID	PIA §2/§4; live policy §8
Book look-ups = ISBN/title only, no student data	PIA P-12; DATA_SHARING_AUDIT.md ; live policy §4
Overseas handling occurs; reasonable steps; APP 8 open	APP 8 brief; PIA APP 8 note
Voice retention 30/90/365, legacy 7-day, 24h unconfirmed	PIA §4; live policy §6
Complaints via support + OAIC escalation	Live policy §10; PIA APP 12/13

Known gaps / adviser must confirm

- **APP 8 sign-off is the gating item.** Sections (6) and (7) assert overseas handling; the reasonable-steps analysis, disclosure-vs-use characterisation and any APP 8.2 exception are **pending counsel** (APP 8 brief). Do not publish until confirmed.
- **Legal entity / APP-entity status.** Insert the contracting entity + ABN; confirm whether Lumi is an APP entity and Lumi/school controller split (APP 8 brief §4).
- **Complaint timeframes.** Confirm the acknowledgement/response timeframes to state in section (5).
- **Sub-processor list link.** Section (3), (6) and (7) reference an available sub-processor list — publish/link the approved PR17 table first.
- **Cloudflare / support-mailbox provider** are not yet in the register; if either processes personal information, the overseas-countries list may need updating.

- **Consent re-acceptance is a separate, single step.** Do **not** bump the version constants as part of this draft; that happens once, after this and the sub-processor table land (remediation Phase 6.5).
- **Sign-off.** Requires the privacy adviser's review and Nic's approval; only then may the live `page.tsx` be updated and the `lastUpdated` date changed.



Lumi Reading · Security & Privacy Evidence

PR17

Sub-processor Register

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT

 **PRIVACY/LEGAL-SENSITIVE DRAFT — PRIVACY ADVISER MUST REVIEW BEFORE PUBLICATION**

This is a **draft** for the appointed Australian privacy adviser to review. It is intended to become a public-facing sub-processor disclosure, so no row may be published, linked from the live privacy policy, or given to a school until the privacy adviser has signed it off. It does **not** modify any live page. Nothing here is legal advice.

ST4S item: PR17 (sub-processors fully described publicly) **Version:** 0.1 — DRAFT for review, not yet signed **Date:** 2026-07-24 **Status:** Draft for review — not yet signed **Primary source:** docs/privacy/VENDOR_DATA_FLOW_REGISTER.md (v1.0, reviewed 17 July 2026)

1. Purpose

This table lists the third-party sub-processors that support the Lumi Reading service, so a school can see who processes personal information on Lumi's behalf, what each one touches, why, and where. It is derived entirely from the internal vendor and data-flow register; where the register marks a vendor's contractual status as **Conditional** or **Blocked**, that is reflected here rather than smoothed over.

A note on terminology: a *sub-processor* is a service Lumi uses to **operate the service on Lumi's (and the school's) instructions**. Using a sub-processor to run the service is **not** the same as sharing data with an independent third party for that party's own purposes — see (DATA_SHARING_AUDIT.md) (PR10).

2. Active sub-processors

Sub-processor / service	Website / contact	Personal information touched	Purpose	Lawful basis (operational)	Processing / storage countries
Google Cloud Firestore (Google LLC / Google Cloud)	cloud.google.com · cloud.google.com/terms/data-processing-addendum	School, child, adult, roster, reading and messaging records	Primary application database that stores and serves all school-scoped records	Service operation — processor acting on Lumi/school instructions under the Google Cloud DPA (APP 6 primary purpose)	Storage & processing: Australia — (australia-southeast1) (Sydney)
Google Cloud Storage (Google Cloud)	cloud.google.com	Optional validated comprehension audio, school logos, book covers	Object storage for user-uploaded media and assets	Service operation — processor under the Google Cloud DPA	User-content buckets: Australia ((australia-southeast1)) . A legacy managed code-source bucket exists in the US (no user content intended)
Cloud Functions / Cloud Run / Eventarc / Cloud Scheduler (Google Cloud)	cloud.google.com	All record types, transiently , during server logic	Server-side authorisation, aggregation, notifications, deletion and media validation	Service operation — processor under the Google Cloud DPA	Australia ((australia-southeast1)) — all 77 live application workloads and all 17 Scheduler jobs verified in-region
Google Cloud Logging (Google Cloud)	cloud.google.com	Application/security events. Direct account/school/child/record identifiers and raw exceptions are prohibited in application log payloads; an admin identity can appear in Google's required audit logs	Operational and security logging; platform audit trail	Service operation — processor under the Google Cloud DPA	Future ordinary logs: Australia ((australia-southeast1)) . Pre-change ordinary logs and unavoidable _Required audit logs are global

Sub-processor / service	Website / contact	Personal information touched	Purpose	Lawful basis (operational)	Processing / storage countries
Google Cloud Secret Manager (Google Cloud)	cloud.google.com	Application secrets only (SendGrid credentials, portal session secret) — no child content intended	Secure storage of service credentials	Service operation — processor under the Google Cloud DPA	Australia (australia-southeast1) — single AU replica (former globally-replicated resources deleted 17 July 2026)
Firebase Authentication / Identity Platform (Google LLC)	firebase.google.com · firebase.google.com/terms/data-processing-terms	Adult UID, email/phone, MFA factors, sign-in and recovery metadata	Account authentication, MFA, and recovery for parents/carers and staff	Service operation — processor under the Firebase Data Processing & Security Terms	United States — Firebase documents Authentication as a US-only processing service
Firebase Cloud Messaging (FCM) (Google LLC)	firebase.google.com	Device push token; adult-facing notification content (may reveal limited reading context)	Delivery of reminders, achievement and comment notifications, school announcements	Service operation — processor under the Firebase terms	Global platform service
Apple Push Notification service (APNs) (Apple Inc.)	developer.apple.com/notifications	Device push token; adult-facing notification content	Push-notification delivery to Apple devices	Service operation — platform provider under Apple developer terms	Global platform service
Firebase App Check (Google LLC)	firebase.google.com	App/device attestation tokens — no intended content data	Client attestation / anti-abuse (enforcement not yet switched on)	Service operation — processor under the Firebase terms	Google service; global support may apply
Firebase Analytics (Google LLC)	firebase.google.com	Pseudonymous, optional usage events — no child/account identifiers, no Lumi UID, no detailed reading fields	Product-usage insight to improve the app	Adult opt-in consent (off by default; withdrawable)	May process outside Australia
Firebase Crashlytics (Google LLC)	firebase.google.com	Optional crash stack traces and app/device diagnostics — no Lumi UID; child content prohibited	Diagnose and fix crashes	Adult opt-in consent (off by default; withdrawable)	May process outside Australia
Twilio SendGrid (Twilio Inc.)	twilio.com · twilio.com/en-us/legal/data-protection-addendum	Adult/school transactional email content; may include adult/school data and temporary credentials — child data excluded by policy	Onboarding, school/staff service and operational email	Service operation — processor under the Twilio DPA (which names the Australian Privacy Act 1988)	SendGrid infrastructure in North America / EU (DataBank, Lumen, Digital Realty); Twilio Inc. may process in the USA
Google Books API (Google LLC)	developers.google.com/books	ISBN / title only — no identity data	Look up public book metadata and covers	Service operation — no personal information sent	Google public API; may process globally
Open Library / Internet Archive	openlibrary.org	ISBN / title / work ID only — no identity data	Look up public book metadata, descriptions and cover images	Service operation — no personal information sent	Overseas public service
Apple App Store (Apple Inc.)	apple.com/legal	Adult/device account, purchase and store-diagnostic data governed by the platform	App distribution and platform account management	Platform/contract necessity — governed by Apple developer + platform terms	Platform-defined global processing
Google Play (Google LLC)	play.google.com	Adult/device account, purchase and store-diagnostic data governed by the platform	App distribution and platform account management	Platform/contract necessity — governed by Google Play developer terms	Platform-defined global processing
Support mailbox provider (provider not yet named — see gaps)	Public contact: support@lumi-reading.com	Privacy, access, correction, deletion and incident reports (potentially any record type a requester includes)	Receive and action privacy and support requests	Service operation — processor	Not yet recorded — provider identity and location to be captured

3. Sub-processors configured but prohibited for production personal data

These are recorded here for completeness because they are technically configured but are **not** permitted to receive production personal information. Per the vendor register they are gated **Blocked** / **Not approved** and must not appear in a "we use these today" public statement.

Service	Proposed purpose	Status
Google Cloud Speech-to-Text	Transcribe optional comprehension audio (AI feature)	Blocked — AI kill switch off; no connected pipeline
Google Vertex AI (Gemini)	Proposed transcript comprehension evaluation, Sydney-regional	Blocked — feature disabled in production; PIA/counsel approval pending
Anthropic / OpenAI / other LLMs	Evaluation alternatives from cost research only	Not approved / superseded (design moved to Vertex-AU; no production call)
Stripe	Future direct-sales design only	Not implemented — no dependency, secret or data flow

4. Lawful-basis caveat (adviser must confirm)

"Lawful basis" above states the **operational** basis Lumi relies on to run the service. Whether Lumi is itself an APP entity, and whether Lumi or the school is the controller for each flow, is **not yet determined** — it is an open question for counsel (**APP_8_CROSS_BORDER_DISCLOSURE_LAWYER_BRIEF.md** §4). The adviser should confirm the correct legal characterisation (processor vs controller; APP 6 primary-purpose vs consent) before this column is published.

5. Evidence index

Claim	Evidence
Vendor list, data types, purposes, locations, statuses	docs/privacy/VENDOR_DATA_FLOW_REGISTER.md (v1.0, 17 Jul 2026)
AU region of Firestore/Storage/Functions/Scheduler	docs/security/AU_RESOURCE_LOCATION_AUDIT_2026-07-17.md ; PIA §4
Firebase Auth US-only path	Firebase Data Processing & Security Terms; PIA §3.1; APP 8 brief §5
SendGrid NA/EU/US sub-processors	docs/privacy/vendor-evidence/2026-07-17/README.md ; Twilio subprocessor snapshot
Book APIs receive ISBN/title only	PIA risk P-12; live privacy page §4; register rows for Google Books / Open Library; and DATA_SHARING_AUDIT.md
Google/Firebase/Twilio DPAs captured (dated, hashed)	docs/privacy/vendor-evidence/2026-07-17/README.md
Secrets migrated to AU-only replicas	APP 8 brief §7; register row (Secret Manager)

6. Known gaps / adviser must confirm

- Contractual status is Conditional for most core vendors.** The register marks Firestore, Storage, Functions, Logging, Firebase Auth, FCM/APNs and SendGrid as **Conditional** pending DPA/support-access/APP 8 review. This table must not be published in a way that implies those reviews are complete.
- Support mailbox provider is not named.** The provider identity, delegate list and mailbox retention are still open (register: "Open release action"). Fill this row before publication.
- Cloudflare is not in the vendor register.** A Cloudflare Worker serves the in-app status banner (**lumistatus.*.workers.dev**) and the marketing/portal sites may transit Cloudflare. If Cloudflare processes any personal information (e.g. IP addresses at the edge), it belongs in this table and in the register. Adviser to confirm scope; see **INT7_SUBPROCESSOR_AGREEMENTS_RECORD.md** .
- Lawful-basis / controller determination pending counsel** (see §4).
- Legal-entity naming.** The public table should name the Lumi contracting entity (and ABN) once confirmed; account-acceptance evidence proving which entity accepted each DPA is held outside Git (register "Evidence still required").
- US/global flows require APP 8 sign-off** before this is presented as a settled cross-border disclosure statement.
- Sign-off.** Requires the privacy adviser's review and Nic's approval before it is linked from any live page or given to a school.

 **Lumi Reading · Security & Privacy Evidence**

PR10

Data Sharing Audit

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT

 **PRIVACY/LEGAL-SENSITIVE DRAFT — PRIVACY ADVISER MUST REVIEW**

This audit reaches a legal-adjacent conclusion (the PR10 answer). It is a **draft** for the appointed Australian privacy adviser to confirm before the readiness answer is relied on. It does **not** modify any live page and is not legal advice.

ST4S item: PR10 (is user data shared with third parties beyond the permitted cases?) **Version:** 0.1 — DRAFT for review, not yet signed **Date:** 2026-07-24 **Status:** Draft for review — not yet signed **Primary sources:** [docs/privacy/VENDOR_DATA_FLOW_REGISTER.md](#), [docs/privacy/PRIVACY_IMPACT_ASSESSMENT.md](#), the live privacy page ([school-admin-web/src/app/legal/privacy/page.tsx](#))

1. What this audit answers

The readiness question PR10 asks whether Lumi shares user data with third parties **beyond the permitted cases** (consent, legal requirement, or operating the service through a processor). Lumi's current baseline answer is **"Yes"**, which this audit concludes is a **misreading**: using processors such as Google/Firebase to run the service is not "third-party sharing" in the sense PR10 means.

The distinction (from [APP_8_CROSS_BORDER_DISCLOSURE_LAWYER_BRIEF.md](#) §2 and OAIC guidance): providing data to a contractor to process **on your instructions, for your purposes** is a *use through a processor*, not a disclosure to an independent third party acting for its own purposes. Lumi does the former; it does not sell, rent, or hand personal information to anyone for that party's own use.

2. Every flow where user data leaves Lumi's systems

Each flow below is classified as a **permitted case** — (C) consent, (L) legal requirement, or (P) service operation via a processor — or as **genuine third-party sharing**. Every row is sourced from the vendor register and PIA.

#	Flow (data leaving Lumi's own code)	Data	Classification	Permitted?
1	Store/serve all records via Firestore	School/child/adult/roster/reading/messaging records	(P) Processor — Google Cloud DPA, AU region	✔ Permitted
2	Media in Cloud Storage	Comprehension audio, logos, covers	(P) Processor — Google Cloud DPA, AU region	✔ Permitted
3	Server logic in Functions / Run / Eventarc / Scheduler	All records, transiently	(P) Processor — AU region	✔ Permitted
4	Cloud Logging	Minimised events (direct identifiers/raw exceptions prohibited); admin identity in required audit logs	(P) Processor — AU ordinary logs; required audit logs global	✔ Permitted
5	Secret Manager	Service credentials only — no child content	(P) Processor — AU-only replica	✔ Permitted (no user PII)
6	Firebase Authentication	Adult UID, email/phone, MFA factors	(P) Processor — US region	✔ Permitted (APP 8 review pending)
7	FCM + APNs push	Device token; adult-facing notification content	(P) Processor — global platform	✔ Permitted
8	Firebase App Check	Device/app attestation token — no content	(P) Processor — global	✔ Permitted (no PII content)
9	Firebase Analytics	Pseudonymous events; no Lumi UID / no child/account identifiers	(C) Adult opt-in, off by default	✔ Permitted (consent)
10	Firebase Crashlytics	Crash stack + device diagnostics; no Lumi UID	(C) Adult opt-in, off by default	✔ Permitted (consent)
11	Twilio SendGrid email	Adult/school transactional content; child data excluded by policy	(P) Processor — NA/EU/US	✔ Permitted (APP 8 review pending)

#	Flow (data leaving Lumi's own code)	Data	Classification	Permitted?
12	Google Books API lookup	ISBN / title only	(P) Processor — no personal info sent	✔ Permitted (see §3)
13	Open Library / Internet Archive lookup	ISBN / title / work ID only	(P) Processor — no personal info sent	✔ Permitted (see §3)
14	Apple App Store / Google Play	Adult/device account, purchase, store diagnostics	(P/contract) Platform terms	✔ Permitted
15	Disclosure within the school community	A child's reading info to that child's teacher/admins and linked parents/carers	Intended in-service disclosure to authorised users (not an external third party)	✔ Permitted
16	Disclosure required by law / to protect safety	As legally compelled	(L) Legal requirement	✔ Permitted (case-by-case)
—	Sale / rental of personal information	—	Does not occur	✔ None
—	Third-party advertising / cross-app tracking	—	Does not occur	✔ None

Basis for the two "does not occur" rows: the live privacy policy states Lumi does **not** sell personal information, does **not** use it for third-party advertising, and does **not** track users across other companies' apps or websites; the vendor register records **no ad SDK** in the app.

3. Book-lookup APIs receive ISBN/title only (confirmed)

The book-metadata lookups (flows 12–13) are the flows most likely to be misread as "sharing", so they are confirmed explicitly:

- The vendor register states the request "includes only ISBN/title" (Google Books) and "only ISBN/title/work ID" (Open Library), with "No identity data intended" for both.
- PIA risk **P-12** requires: "Send only ISBN/title; never include child, school, notes or account identifiers; retain manual entry" — rated Low/Controlled.
- The live privacy policy §4 states: "No student information is sent in these look-ups."
- A manual-entry fallback exists, so the lookup is helpful but replaceable.

Conclusion for §3: book-lookup APIs receive bibliographic identifiers only (ISBN/title/work ID) and **no student or account data**. *(Adviser note: this is asserted from the register/PIA/policy; a source-level confirmation of the request payload — see gaps — would make it evidenced rather than documented.)*

4. Conclusion — the PR10 answer

Every flow in §2 falls into a **permitted case**: service operation via a processor, adult consent (optional diagnostics only), a legal requirement, or an intended in-service disclosure to the child's own authorised school community. **No flow is genuine third-party sharing** — Lumi does not sell personal information, does not use it for advertising, and does not disclose it to any party for that party's own purposes.

PR10 recommended answer: "No — we do not share user data outside the permitted cases." Using processors (Google/Firebase, SendGrid, push platforms) to operate the service is **not** third-party sharing.

Keep this audit as the evidence behind that answer.

5. Evidence index

Claim	Evidence
Full list of egress flows, data, locations	docs/privacy/VENDOR_DATA_FLOW_REGISTER.md
Processor vs disclosure distinction	APP_8_CROSS_BORDER_DISCLOSURE_LAWYER_BRIEF.md §2; OAIC APP 8 guidance
No sale / no ad tracking / no ad SDK	Live privacy page §2; vendor register (Apple/Google row: "No ad SDK")
Book APIs get ISBN/title only	Register (Google Books / Open Library rows); PIA P-12; live privacy page §4
Analytics/Crashlytics opt-in, off by default, no Lumi UID	PIA §2, §4; live privacy page §8
In-school disclosure is role/class/child-scoped	PIA APP 6 note; firebase.rules ; ACCESS_CONTROL_POLICY.md
Companion sub-processor detail	SUB_PROCESSOR_TABLE.md (PR17)

6. Known gaps / adviser must confirm

- **Processor-vs-disclosure characterisation is counsel's call.** This audit applies the OAIC framing operationally; the formal APP 8 disclosure/use determination per flow is **pending counsel** (APP 8 brief §5, §8).
- **US/global processor flows (Firebase Auth, FCM/APNs, SendGrid) still need the APP 8 reasonable-steps sign-off** before "permitted" is legally settled — the classification here is that they are processor flows, not that the cross-border assessment is complete.
- **Book-lookup payload is documented, not yet source-verified.** A quick code confirmation that only ISBN/title is placed on the outbound request would upgrade §3 from "documented" to "evidenced".
- **Cloudflare edge.** If a Cloudflare Worker/CDN sits in front of any user request, edge processing (e.g. IP addresses) is an egress not captured above; confirm scope (see `SUB_PROCESSOR_TABLE.md` and `INT7_SUBPROCESSOR_AGREEMENTS_RECORD.md`).
- **Support mailbox provider** is unnamed; requests emailed to support leave via that provider — classify once the provider is recorded.
- **Sign-off.** The PR10 answer change to "No" should be confirmed by the privacy adviser and Nic before it is entered in the readiness check.

Lumi Reading · Security & Privacy Evidence

INT7

Sub-processor Agreements (DPA) — Record

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

TEMPLATE — TO POPULATE

 **PRIVACY/LEGAL-SENSITIVE DRAFT — PRIVACY ADVISER MUST REVIEW**

This is a **template** for recording acceptance of each vendor's data-processing terms. **Nic records the actual acceptances** (dates, contracting entity, evidence files). The rows below are **placeholders** — they do **not** assert that any agreement has been accepted. Do not treat a placeholder as evidence. Store signed/account-specific artefacts outside Git in an access-controlled location and reference them here. Not legal advice.

ST4S item: INT7 (written data agreements with integrated third parties) **Version:** 0.1 — DRAFT for review, not yet signed **Date:** 2026-07-24 **Owner of actual acceptances:** Nic (Lumi owner/director) **Evidence location:** `docs/privacy/vendor-evidence/` (public terms, dated + hashed) + an access-controlled legal folder outside Git (account-acceptance proof)

1. Purpose

INT7 asks whether Lumi has **written data agreements** with the third parties it integrates. This record captures, per vendor: the agreement name, whether/when it was accepted, the contracting Lumi entity, and where the evidence lives. It works with the vendor register (`docs/privacy/VENDOR_DATA_FLOW_REGISTER.md`) and the dated public-terms pack (`docs/privacy/vendor-evidence/2026-07-17/`).

Important distinction (from `vendor-evidence/2026-07-17/README.md`): capturing a vendor's *public* terms proves the terms existed and their content on a date; it does **not** prove which Lumi legal entity **accepted** them, when, or on which billing account. INT7 needs the latter — the acceptance record — which only Nic can produce from the vendor consoles/accounts.

2. Acceptance record (Nic completes)

Fill each row from the vendor console / account. Use **role labels**, never personal emails or phone numbers, for any named contact. Set "Accepted?" to **Yes** only when the acceptance evidence is captured and filed.

#	Vendor / integration	Agreement name	Accepted?	Date accepted	Contracting Lumi entity	Acceptance evidence location
1	Google Cloud (Firestore, Storage, Functions/Run, Logging, Secret Manager)	Google Cloud Data Processing Addendum (+ service-specific terms)	☐ Pending	—	<code>[entity]</code>	Public terms: <code>vendor-evidence/2026-07-17/raw/google-cloud-data-processing-addendum.txt</code> . Account-acceptance proof: <code>[legal folder]</code>
2	Firebase (Authentication, FCM, App Check, Analytics, Crashlytics)	Firebase Data Processing and Security Terms	☐ Pending	—	<code>[entity]</code>	Public terms: <code>vendor-evidence/2026-07-17/raw/firebase-data-processing-security-terms.txt</code> . Account proof: <code>[legal folder]</code>
3	Twilio SendGrid (email)	Twilio Data Protection Addendum	☐ Pending	—	<code>[entity]</code>	Public terms: <code>vendor-evidence/2026-07-17/raw/twilio-data-protection-addendum.txt</code> . Account proof: <code>[legal folder]</code>
4	Cloudflare (status-banner Worker; any CDN/edge in front of sites)	Cloudflare Data Processing Addendum	☐ Pending	—	<code>[entity]</code>	Public terms: <code>[capture to vendor-evidence/]</code> . Account proof: <code>[legal folder]</code> — also add Cloudflare to the vendor register
5	Apple (App Store distribution, APNs)	Apple Developer Program License Agreement (+ any Apple DPA/addendum)	☐ Pending	—	<code>[entity]</code>	Enrolment/agreement export: <code>[legal folder]</code>
6	Google Play (distribution)	Google Play Developer Distribution Agreement (+ Play data terms)	☐ Pending	—	<code>[entity]</code>	Enrolment/agreement export: <code>[legal folder]</code>
7	Support mailbox provider (provider not yet named)	Provider terms / DPA	☐ Pending	—	<code>[entity]</code>	<code>[name the provider first — see gaps]</code>

(Google Books and Open Library are public metadata APIs receiving ISBN/title only — no personal information — so they are not data-processing counterparties. Record their public privacy/retention terms in the vendor register for completeness, but no DPA is expected. Confirm with the adviser.)

3. The one-line vendor-gate rule (feeds EV6)

To keep this record complete over time, adopt the following standing rule (to be added to the EV6 change/vendor-management control):

No new SDK, API, sub-processor or vendor secret may be added to production until the vendor register records its purpose, data, location, retention, deletion, contract/DPA, security owner and APP 8 decision, and this INT7 record has the accepted data agreement filed.

This mirrors data-flow rule 3 already in the vendor register (`VENDOR_DATA_FLOW_REGISTER.md` §Data-flow rules) and makes it a release gate.

4. Evidence index

Item	Location
Dated + hashed public terms (Google/Firebase/Twilio/OAIC)	<code>docs/privacy/vendor-evidence/2026-07-17/README.md</code>
Vendor register (purpose/data/location/status per vendor)	<code>docs/privacy/VENDOR_DATA_FLOW_REGISTER.md</code>
Companion public sub-processor table	<code>SUB_PROCESSOR_TABLE.md</code> (PR17)
Cross-border/APP 8 legal framing	<code>APP_8_CROSS_BORDER_DISCLOSURE_LAWYER_BRIEF.md</code>
Account-acceptance / billing proof	Access-controlled legal folder outside Git (do not commit)

5. Known gaps / adviser must confirm

- **All rows are Pending.** No acceptance date, contracting entity, or account proof is filed yet — every "Accepted?" is `□ Pending`. This record must not be read as evidence that agreements are in place.
- **Nic must supply the account-acceptance proof.** Public terms alone do not satisfy INT7; Nic exports/screenshots each console acceptance and files it in the access-controlled legal folder, then updates the table.
- **Cloudflare is not yet in the vendor register.** A Cloudflare Worker serves the in-app status banner and Cloudflare may sit in front of the sites; capture its DPA and add it to the register (and to `SUB_PROCESSOR_TABLE.md`) — or record a reasoned finding that it processes no personal information.
- **Support mailbox provider unnamed.** Name the provider, then record its terms.
- **Contracting entity / ABN.** Confirm the single Lumi legal entity that accepted each agreement (APP 8 brief §4 — entity/APP-entity status open).
- **Do not store secrets, billing records, account numbers or signed private agreements in Git** — reference their access-controlled location only (`vendor-evidence/2026-07-17/README.md` closing note).
- **Sign-off.** The privacy adviser confirms this record satisfies INT7 once the rows are completed with real, filed evidence.



Lumi Reading · Security & Privacy Evidence

EV11

Vulnerability Assessment Report

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

FINAL · 2026-07-24

Document: ST4S evidence **EV11** (Vulnerability Assessment). Feeds **EV10** (interim, pending the independent external penetration test). **Version:** 1.0 · **Date:** 24 July 2026 **Assessment type:** Authorised, self-managed, source-code-assisted security assessment **Target:** Lumi Reading — Firebase/GCP application (`lumi-ninc-au` , `australia-southeast1`) **Prepared by:** Security Lead (Nic) with an AI orchestration (Opus 4.8 finders + Fable reviewer/verifier) **Classification:** Internal — no secrets, credentials, tokens, or personal information are reproduced in this report; findings reference code by file/location only. **Companions:** `SECURITY_ASSESSMENT_ORCHESTRATION_PLAN.md` (method) · `FINDINGS_REGISTER.md` (live register) · `ASSESSMENT_STATUS.md` (status board) · `PENTEST_DRYRUN_FINDINGS_2026-07-20.md` (prior in-house pass, deduped).

1. Executive summary

A structured, source-code-assisted assessment of the Lumi Reading platform was conducted 23–24 July 2026, covering the Firestore/Storage security rules, Cloud Functions, the `packages/server-ops` privileged core, both Next.js portals, the Flutter application, and the CI/CD posture. The assessment used a multi-agent orchestration (parallel Opus 4.8 analysts, each finding verified by a Fable reviewer) with all dynamic testing confined to the Firebase Emulator Suite on synthetic data; production was treated as read-only.

Overall posture is strong. Multi-tenant isolation is structurally sound (every authorization decision derives from a server-written membership document, never a client claim), both portals close the historically-known cookie-forgery / IDOR / self-provisioning classes, and Cloud Functions callables are consistently well-authorised.

Nine application/rules findings were identified (1 High-framed, several Medium, the rest Low/Info), plus a clean SAST baseline (1 low item) and a dependency (SCA) baseline. The single most material finding — **F-01**, a new create-vs-update rules asymmetry allowing a forged entitlement — was not present in the prior in-house pass; it was confirmed dynamically in the emulator and fixed.

Remediation is complete for every fixable finding. As of this report, F-01, F-02, F-03, A2/F-09, SAST-01, F-07 and F-04 are all fixed, regression-tested, merged, and **deployed to production**. Two findings are accepted-by-design (F-06, F-08), and one (F-05, App Check enforcement) is a launch-gated control tracked separately. Each rules fix is protected by a new emulator regression test wired into CI.

2. Scope

In scope (Lumi's own code and configuration):

- `firestore.rules` , `storage.rules` and their test suites.
- Cloud Functions (`functions/src/**`) — ~35 callables, 1 IAM-locked HTTP function, ~20 scheduled, ~27 event-triggered.
- `packages/server-ops/**` — the privileged operation modules.
- School portal (`school-admin-web/`) and super-admin portal (`admin/`) — Next.js SSR API routes, session/auth.
- Flutter application (`lib/**`) — MASVS/MASTG static review.
- CI/CD security tooling.

Out of scope (per the vendor register): Google/Firebase platform internals, SendGrid/Twilio, Apple/Google stores, Open Library / Google Books services — the assessment tests Lumi's *configuration and use* of these, never the vendors' own infrastructure.

Explicitly excluded: DoS/load/volumetric testing, password spraying, credential stuffing, phishing/social engineering, destructive exploits, data exfiltration, stealth/evasion, unbounded fuzzing, and any action against real child data or production tenants.

3. Methodology

- Orchestration:** parallel Opus 4.8 analysts each mapped one surface (backend authz, rules, portals, vendor boundary, environment); a Fable reviewer de-duplicated against the closed known-issues list, reconciled cross-analyst conflicts, and adversarially verified every High/Critical against source before it was accepted.
- Standards:** OWASP ASVS / WSTG, OWASP Top 10 (2025) + SANS CWE Top 25, MASVS/MASTG (mobile).
- Dynamic testing:** Firebase Emulator Suite (`demo-lumi-*` throwaway projects), **synthetic data only**. Each confirmed finding was reproduced as a client-SDK proof-of-concept, then converted into a permanent regression test (`functions/test/security_poc.rules.test.js`).
- Static tooling:** `semgrep` (SAST), `npm/pnpm audit` + `osv-scanner` config (SCA), `gitleaks` (secrets).
- Production:** read-only. No exploitation. TLS/config scanning (S1/S3/S5) is deferred pending an explicit written scope exception.

4. Findings summary

Severity is Fable-reconciled (control-bypass framing vs. current blast radius). Status is as of 24 Jul 2026.

ID	Finding	Severity	ST4S	Status
F-01	Student <code>create</code> rule omitted the server-owned-field denylist → forgeable live <code>access</code> entitlement (self-provisionable)	High / Med	S4, A13	✅ Fixed + deployed
F-02	School <code>create</code> rule omitted the commercial-fields guard (subscription/access/accessMode/isDemo)	Medium	S4	✅ Fixed + deployed
F-03	Class <code>update</code> allowed a teacher to reassign ownership (teacherId/teacherIds)	Med-Low	S4	✅ Fixed + deployed
F-04	<code>server-ops</code> destructive ops had no in-module authz (single-layer)	Med (def-in-depth)	A5, S4, A13	✅ Fixed + deployed
F-05	App Check enforcement OFF on all callables	Low-Med	A13, S7	🔒 Launch-gated (staged rollout)
F-06	Storage cover first-claim open to any authenticated user	Low	S4, PF51	📄 Accept-as-designed
F-07	<code>books/lookup</code> ISBN param injection + external-API cost amplification, no rate limit	Low	Q5	✅ Fixed + deployed
F-08	Portal CSRF relies on <code>SameSite=Lax</code> alone	Low	A13	📄 Accept-as-designed
F-09	Portal <code>createUser</code> password minimum 6 chars (part of A2)	Low	A2	✅ Fixed + deployed
SAST-01	Super-admin MFA-crypto GCM decrypt without pinned <code>authTagLength</code>	Low	Q5, EV13	✅ Fixed + deployed
SCA-01	9 transitive advisories (8 mod, 1 high) under <code>firebase-admin</code>	High/Mod	T2/T3/AP1	🔍 Tracked (no clean upstream fix)
A2	Passwords enforced at 6–8 chars (not the claimed 14+/complexity)	—	A2	✅ Fixed + deployed
M-01...M-08	Mobile AP2 items (Hive-at-rest, audio/widget at-rest, no pinning, etc.)	Low–Med	AP2	Mostly known/accepted (see §5.4)

5. Detailed findings

5.1 F-01 — Student-create entitlement forgery (S4/A13) — FIXED + DEPLOYED

Description. The student `create` rule (`firestore.rules`) required only role + `schoolId` match, omitting the server-owned-field denylist (`access`, `parentIds`, `autoAward`, `pendingDeletion`, `feelingsByDay`, `latestParentComment`) that the `update` rule enforced. The server trigger `grantAccessOnStudentCreate` bails when `access` is pre-seeded, so nothing reconciled a forged value. **Impact.** A schoolAdmin/teacher — including a self-provisioned admin (client school-create → admin bootstrap → student create) — could mint a student that is entitlement-live from creation, bypassing `studentAccessLive`, the rules' single licensing-enforcement point. A licensing/authorization-control bypass; blast radius currently limited (within-tenant; AI eval dark) but latent for any access-gated paid feature. **Not present in the prior in-house pass** (which tested `update` but not `create`). **Remediation.** One shared field list now guards create and update; the trigger is unchanged. **Verification:** emulator PoC confirmed the pre-fix exploit and now confirms denial; full rules suite 172/172 green. **Fix commit** `0d31809`, **deployed** `firestore:rules`.

5.2 F-02 — School-create commercial-field seeding (S4) — FIXED + DEPLOYED

School `create` omitted the guard the `update` path enforced, letting a creator self-seed `subscription`/`access`/`accessMode`/`isDemo`. Fixed with a `schoolCommercialFieldsAbsentOnCreate()` guard; emulator regression test added. Deployed.

5.3 F-03 — Class-update ownership reassignment (S4) — FIXED + DEPLOYED

Class `update` authorised a teacher-of-class with no field restriction, allowing reassignment of `teacherId`/`teacherIds` (hand the class to an attacker uid, or self-removal). Fixed by a `classOwnershipUnchanged()` guard on the teacher branch (schoolAdmins retain reassignment). Emulator regression test added. Deployed.

5.4 F-04 — server-ops single-layer authorization (A5/S4/A13) — FIXED + DEPLOYED

The `packages/server-ops` destructive operations (offboard a school, delete parent accounts, grant dev-access, disable staff auth) carried no internal authorization — the only gate was the calling super-admin portal route's `verifySession()`. Not exploitable at assessment time (all routes gate), but single-layer. **Remediation:** a fail-closed `assertSuperAdmin(db, actor.uid)` — mirroring `admin/isSuperAdminViaFirestore` and `functions/isSuperAdmin` (`/superAdmins/{uid}` doc + `SUPER_ADMIN_UIDS` bootstrap env) — added to the five destructive super-admin-only ops. No behaviour change for legitimate callers. Unit test `authority.parity.test.ts`. **PR #561, auto-deployed via** `admin-deploy`.

5.5 F-05 — App Check enforcement OFF (A13/S7) — LAUNCH-GATED

Firebase App Check is unenforced on all callables (client attestation flags default off), enabling scripted abuse of low-auth callables (SMS toll-fraud, code enumeration, marketing spam). Enabling now would lock out clients because valid store-signed App Attest / Play Integrity evidence requires the app to be published. Tracked in `REMAINING_HARDENING_RUNBOOK.md` §6 as a staged rollout. **Not a code defect.**

5.6 F-06 — Storage cover first-claim (S4/PF51) — ACCEPT-AS-DESIGNED

Any authenticated non-demo user may first-claim an unclaimed community-book cover. Documented as an intended tradeoff (`storage.rules.test.js:373`): Storage rules cannot read Firestore for role, accounts are invite-only, covers are non-personal, and the enforced protections (`uploaderUid = caller`; no overwrite of another user's cover) stand. Optional uplift: callable-mediated upload with a server-side role check.

5.7 F-07 — books/lookup injection + amplification (Q5) — FIXED + DEPLOYED

The `books/lookup` route interpolated a caller-supplied ISBN into external Google Books / Open Library URLs after stripping only separators, and had no rate limit (query-parameter injection + external-API cost amplification for any authenticated staff member). **Remediation:** strict ISBN-10/13 validation (route zod regex + `isValidIsbn` guard) so only clean digits reach the external URLs, plus a 60/min per-user rate limit via the existing `consumeRateLimit`. Portal typecheck clean. Deployed (school portal).

5.8 F-08 — CSRF via SameSite=Lax (A13) — ACCEPT-AS-DESIGNED

State-changing portal routes rely on `SameSite=Lax` cookies (a same-origin `Origin` guard exists only on demo-allocation + auth-session routes). Cross-site exploitation is infeasible given Lax + Firebase PSL-separated default domains; residual risk is a same-registrable-domain sibling on custom domains. Recommendation: extend the existing `assertSameOrigin` guard to all mutation routes when convenient.

5.9 F-09 / A2 — Password strength (A2) — FIXED + DEPLOYED

Passwords were enforced at 6–8 characters depending on surface (portal `createUser` min-6; app signup 8 + upper/lower/digit; temp passwords 12 chars, no symbol) — the ST4S submission claimed 14+/complexity. **Remediation:** a shared 14+/upper-lower-digit-symbol validator across the portal (API + modal) and the three app signup screens; all three temp-password generators produce 16-char/symbol passwords compliant *by construction* (the Admin-SDK paths bypass any policy); and the Firebase Console password policy was set to **Require / min 14 / all four classes** (evidence captured). A2 is now true across every surface. Deployed (portal + `processStaffOnboardingEmail`); app-side validators ship with the next app release; console policy is the server-side gate for client-SDK signups + hosted resets.

5.10 Mobile (AP2 / MASVS) findings

Static MASVS/MASTG review. Good posture: the one PII-bearing signup box is AES-256 encrypted with a Keychain/Keystore key; deep-link validation is strict (scheme/host/path allowlist, no query-param forwarding); no WebView; Analytics/Crashlytics off until adult opt-in; `allowBackup=false` + data-extraction rules exclude every domain from cloud-backup/device-transfer.

- **M-01** (Med, known): Hive offline caches (`students/reading_logs/pending_sync`) unencrypted at rest — local-access-only (rooted/forensic).
- **M-02** (Low-Med, new): comprehension audio written unencrypted pre-sync, then deleted.
- **M-03** (Low, new): iOS widget App-Group stores child `firstName` + streak as plaintext JSON.
- **M-04**: App Check backend enforcement off (= F-05).
- **M-05–M-08** (Low/Info): no cert pinning (acceptable with Firebase), no root/anti-tamper, Firebase API keys in bundle (not a secret), `debugPrint` in release (reviewed clean). An external MASTG tester should perform rooted-device at-rest inspection, backup-vector extraction, deep-link fuzzing, App Check replay, MITM-with-user-CA, and runtime/Frida checks.

6. Automated scanning baselines

- **SCA-01 (dependencies):** `npm audit` on `functions` reports 9 transitive advisories (8 moderate, 1 high) — all under `firebase-admin` (`@google-cloud/firestore` → `google-gax`; `@google-cloud/storage` → `teeny-request` → `uuid`). No clean upstream fix (`--force` breaks). Tracked; Dependabot + osv-scanner now watch it.
- **SAST:** `semgrep` (typescript/javascript/secrets/owasp-top-ten over functions/portals/server-ops) — **one** finding total (SAST-01, low, now fixed), no secrets flagged. A clean baseline consistent with the gitleaks-clean history.
- **Secrets:** `gitleaks` full-history — clean.
- **New CI controls (AP1/T1/T2/EV11):** Dependabot (npm/pub/actions), osv-scanner and semgrep workflows (monthly + on-demand; per-PR wiring pending ref verification), and this findings register.

7. Positive assurance

- **Multi-tenant isolation (S4):** dynamically proven — a school-A teacher cannot read school-B data directly nor via an unconstrained collection-group sweep (`security_poc.rules.test.js`, S4 test). No cross-tenant path was found anywhere.
- **Deny-by-default (A13):** strong — implicit deny + explicit `allow read, write: if false` on ~20 server-only collections; no recursive wildcard.
- **Portal session/auth:** the historical cookie-forgery, reset-password IDOR, teacher self-provisioning and claims-clobber classes are all closed with visible fixes; sessions are revocation-aware and fail closed.

8. Residual & accepted risks / recommendations

Item	Disposition	Recommendation
F-05 App Check	Launch-gated	Enable (Require) once the app ships store-signed attestation

Item	Disposition	Recommendation
F-06 cover first-claim	Accepted	Optional: callable-mediated upload with role check
F-08 CSRF (SameSite)	Accepted	Extend <code>assertSameOrigin</code> to all mutation routes
SCA-01 firebase-admin transitives	Tracked	Bump <code>firebase-admin</code> when a patched release lands
M-01/M-02/M-03 at-rest	Known/new	Optional: encrypt Hive boxes + the audio staging dir with a Keychain/Keystore key
Wave 3 (TLS/config prod scan)	Not performed	Run under an explicit read-only scope exception (feeds S1/S3/S5)
External penetration test	Outstanding	Independent CREST/OSCP test for EV10 (scoping pack ready)

9. ST4S mapping

Directly evidenced or advanced by this assessment: **S4, A13, A5** (tenant isolation, deny-by-default, privileged-access — validated + hardened, F-01–F-04); **A2** (passwords — now true); **Q5** (security testing performed to a framework); **AP1/T1/T2** (scanning cadence + Dependabot); **AP2** (mobile MASTG static review); **EV11** (this report); **EV10** (interim — external test outstanding). SAST-01 also feeds **EV13** (secure SDLC).

10. Remediation status

All fixable findings are remediated and deployed to production as of 24 Jul 2026: F-01, F-02, F-03 (`firestore:rules`), A2/F-09 (portal + functions + console policy), SAST-01 + F-04 (super-admin portal, `admin-deploy`), F-07 (school portal). Every rules fix carries an emulator regression test wired into CI. Remaining items are launch-gated (F-05), accepted-by-design (F-06, F-08), upstream-tracked (SCA-01), or require the outstanding independent external penetration test (EV10) and a scoped production TLS scan (Wave 3).

— End of report —



Lumi Reading · Security & Privacy Evidence

S1 / S3 / S5

TLS & Cryptography Profile

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

FINAL · 2026-07-24

Document: ST4S evidence for S1 (encryption in transit), S3 (encryption on upload), S5 (proper TLS certificates); the "crypto profile" from the remediation plan Phase 3. **Version:** 1.0 · **Date:** 24 July 2026 **Method:** Wave 3 of the self-managed assessment — a **strictly passive, read-only** TLS + security-header scan (OpenSSL 3.6.2 handshakes + HTTP HEAD), authorised by the Security Lead for the listed Lumi-owned hostnames. No exploitation, authentication, writes, or load. No secrets or personal data are involved.

1. Scan results (per endpoint)

Protocols: whether the server *accepts* a handshake at each TLS version. "Negotiated" is the default (preferred) protocol/cipher.

Endpoint	TLS 1.0	TLS 1.1	TLS 1.2	TLS 1.3	Negotiated	Cert issuer / key / sig	HSTS
<code>lumi-reading.com</code> (marketing)	✗ rejected	✗ rejected	✓	✓	TLS 1.3 · AES-128-GCM	Google Trust Services (WR3) · RSA-2048 · SHA-256 · exp 2026-10-08	<code>max-age=31556926</code> (no includeSubDomains/preload)
<code>lumi-school-admin-au.web.app</code> (school portal)	✗	✗	✓	✓	TLS 1.3 · AES-128-GCM	Google Trust Services (WR4) · RSA-2048 · SHA-256 · exp 2026-10-18	<code>max-age=31556926; includeSubDomains; preload</code>
<code>lumi-dev-admin-au.web.app</code> (super-admin)	✗	✗	✓	✓	TLS 1.3 · AES-128-GCM	Google Trust Services (WR4) · RSA-2048 · SHA-256 · exp 2026-10-18	<code>...; includeSubDomains; preload</code>
<code>lumi-ninc-au.web.app</code> (default hosting)	✗	✗	✓	✓	TLS 1.3 · AES-128-GCM	Google Trust Services (WR4) · RSA-2048 · SHA-256 · exp 2026-10-18	<code>...; includeSubDomains; preload</code>
<code>lumi-marketing-au.web.app</code>	✗	✗	✓	✓	TLS 1.3 · AES-128-GCM	Google Trust Services (WR4) · RSA-2048 · SHA-256 · exp 2026-10-18	<code>...; includeSubDomains; preload</code>
<code>lumistatus.aged-morning-985b.workers.dev</code> (status worker, public banner only)	✗	✗	✓	✓	TLS 1.3 · AES-256-GCM	Let's Encrypt (YE1) · ECDSA P-256 · SHA-384 · exp 2026-08-27	(none)

Every endpoint carrying customer data enforces TLS 1.2+ only (TLS 1.0/1.1 handshakes are refused), negotiates TLS 1.3, and uses AEAD (AES-GCM) ciphers with a valid, in-date, publicly-trusted certificate.

2. Crypto profile (for the ST4S answers)

- In transit (S1/S3):** TLS 1.2 or above only — verified by scan (1.0/1.1 rejected; 1.3 negotiated). AEAD ciphers only (AES-128/256-GCM).
- Certificates (S5):** publicly-trusted CAs (Google Trust Services; Let's Encrypt), RSA-2048/SHA-256 or ECDSA-P256/SHA-384 — modern, in-date, auto-renewed by the hosting platforms.
- At rest:** AES-256, Google-managed for Firestore, Cloud Storage and backups (`australia-southeast1`) — per the vendor register and `AU_RESOURCE_LOCATION_AUDIT_2026-07-17.md` ; not scannable from outside, evidenced by Google's platform documentation.
- Password hashing:** script, managed by Firebase Authentication / Identity Platform — Firebase-documented; combined with the 14+/complexity policy now enforced (see A2).

Conclusion: S1, S3 and S5 can now truthfully take the strongest option — "Encryption AES-128+ / Hashing SHA-256+ / TLS 1.2 or above only (Tier 1)."

3. Minor hardening recommendations (non-blocking)

These do not affect the S1/S3/S5 answer; they are optional uplift.

1. `lumi-reading.com` HSTS lacks `includeSubDomains; preload` (the four `.web.app` sites have the full directive). Add them on the custom-domain HSTS config.
2. **Status worker** (`workers.dev`) sets no HSTS and no security headers. It serves only a public status banner (no personal data), so this is low-risk — optionally enable HSTS via Cloudflare, or move it behind a custom domain with min-TLS pinned (already TLS 1.2+ in practice).
3. **Portal response headers:** the root responses carry HSTS but not `Content-Security-Policy`, `X-Frame-Options`, or `X-Content-Type-Options`. **DONE for the portals (2026-07-24, PR #569):** `X-Content-Type-Options: nosniff`, `X-Frame-Options: SAMEORIGIN`, and `Referrer-Policy: strict-origin-when-cross-origin` added to school-admin-web + admin (deployed + verified live) and the marketing static-hosting config (`firebase.json`). A full `Content-Security-Policy` remains **deferred** (needs nonce-based Next middleware; risks breaking the app) — a separate deliberate task. Relates to S11 security configuration, not S1/S3/S5.

4. Scope & authorisation

Passive, read-only, authorised by the Security Lead (24 Jul 2026) as a narrow written exception for the six Lumi-owned hostnames above. The scan tests **Lumi's TLS configuration** of Firebase Hosting / Cloudflare, not the vendors' own infrastructure. Stop-on-anomaly was in force; no anomalies were encountered.

— End of profile —